Cube 3 - Sécuriser les infrastructures du SI

Théo BORTOLOTTO
MICSI NY 24-26 L18 GROUPE 1

SMARTFACTORY

CESI
ÉCOLE D'INGÉNIEURS

Table des matières

1. Introduction et contexte 6
1.1 Contexte client 6
1.2 Objet de la mission 6
1.3 Périmètre étudié 6
1.4 Méthodologie 6
2. Méthodologie d'audit et référentiels retenus 7
2.1 Démarche d'audit 7
2.2 Référentiels et bonnes pratiques 7
2.3 Critères d'analyse 7
3. Audit de l'existant et analyse des écarts 7
3.1 Vue d'ensemble de l'infrastructure actuelle 7
3.2 Analyse par domaine 8
3.2.1 Systèmes et serveurs 8
3.2.2 Réseau et interconnexion 8
3.2.3 Identités et accès 8
3.2.4 Sauvegarde et restauration 9
3.2.5 Supervision, détection et logs 9
3.2.6 Données et applications critiques 9
3.2.7 Gouvernance et organisation 10
3.3. Tableau des écarts majeurs 10
3.3.1 Traçabilité des constats d'audit 12
4. Exigences de sécurité, obligations et niveau de conformité 13
4.1 Exigences applicables 13
4.1.1 Traçabilité, journalisation et supervision 13
4.1.2 Sauvegarde et résilience 13
4.1.3 Séparation des environnements et segmentation 13
4.2. Analyse de conformité 13
4.2.1. Matrice de conformité et plan de mise en conformité 14
4.3. Niveau de maturité 15
5. Analyse de risques avec la méthode EBIOS Risk Manager 16
5.1. Atelier 1 - Cadrage et socle 16
5.1.1. Périmètre de l'étude 16
5.1.2. Valeur métier 16

5.1.3. Biens essentiels 17
5.1.4. Biens supports 18
5.1.5. Événements redoutés 19
5.1.6. Évaluation de la gravité 20
5.1.7. Socle de sécurité existant 21
5.2. Atelier 2 - Sources de risque 21
5.2.1. Typologie des sources de risque 21
5.2.2. Analyse des motivations et capacités 23
5.2.3. Positionnement des menaces 23
5.3. Atelier 3 - Scénarios stratégiques 24
5.3.1. Identification des scénarios stratégiques 24
5.3.2. Analyse synthétique des scénarios 26
5.3.3. Priorisation des scénarios 26
5.4. Atelier 4 - Scénarios opérationnels 27
5.5. Atelier 5 - Traitement des risques 28
5.5.1. Évaluation des risques 29
5.5.2. Stratégie de traitement des risques 30
5.5.3. Priorisation des actions 30
6. Comparatif des solutions du marché 31
6.1 Introduction 31
6.2 Benchmark des solutions cloud 31
6.3 Choix de la solution cloud 32
6.4 Benchmark des briques de sécurité 33
6.4.1 Gestion des accès (IAM / Bastion) 33
6.4.2 Sécurité réseau 33
6.4.3 Protection postes et serveurs 34
6.4.4 Supervision et détection 34
6.4.5 Sauvegarde 34
6.4.6 ERP et applications critiques 34
6.5 Synthèse globale 34
7. Architecture cible sécurisée 35
7.1 Vision globale et choix des solutions 35
7.2 Architecture système cible 35
7.3 Architecture réseau et segmentation 36

7.4 Gestion des flux et règles de filtrage 37
7.5 Sécurisation des accès et administration 38
7.6 Supervision et détection 38
7.7 Sauvegarde et résilience 39
8. Plan de remédiation et portefeuille projets 39
8.1 Approche méthodologique du plan de remédiation 39
8.2 Logique de priorisation 39
8.3 Plan de remédiation 40
8.4 Tableau du portefeuille projets 42
8.5 Feuille de route 43
9. Détection, supervision et surveillance des menaces 44
9.1 Besoin de surveillance du système d'information 44
9.2 Outils de détection et de supervision retenus 45
9.3 Cas d'usage de détection 46
9.4 Processus de traitement des incidents 47
9.5 Indicateurs de performance de la détection et de la réponse 48
10. Veille professionnelle et gouvernance de la sécurité 49
10.1 Organisation de la veille 49
10.2 Sources de veille 50
10.3 Processus de veille et de diffusion 50
10.4 Plan d'audit et lien avec la veille 51
10.5 Gouvernance de la sécurité 52
10.6 Pilotage via un outil GRC (CISO Assistant) 52
10.6.1 Rôle de CISO Assistant dans le dispositif de gouvernance 52
10.6.2 Données pilotées dans l'outil 52
10.6.3 Exemple de structuration du pilotage dans CISO Assistant 53
10.6.4 Workflow de pilotage 53
10.6.5 Apport de l'outil à la décision 54
10.6.6 Limites et conditions de réussite 54
11. Indicateurs, tableaux de bord et aide à la décision 55
11.1 Principes des indicateurs de sécurité 55
11.2 Tableau de bord opérationnel 55
11.3 Tableau de bord de pilotage (RSSI / IT) 56
11.4 Tableau de bord direction (COMEX / Direction) 56

11.5 Lien avec les outils de supervision et GRC 57
12. PCA, PRA et plan de communication de crise 58
12.1 Principes de continuité et de reprise 58
12.2 Identification des services critiques 58
12.3 Objectifs de reprise (RTO / RPO) 59
12.4 Organisation de la gestion de crise 59
12.5 Plan de communication de crise 60
13. Gestion d'un scénario de crise cyber 62
13.1 Présentation du scénario retenu 62
13.2 Détection de l'attaque 62
13.3 Qualification de l'incident 63
13.4 Réponse immédiate et contre-mesures 63
13.5 Organisation opérationnelle de la crise 64
13.6 Restauration et rétablissement 64
13.7 Vérification d'intégrité avant remise en production 65
13.8 Évaluation des dommages 65
13.9 Retour d'expérience et axes de renforcement 66
13.10 Mise à jour du plan de crise 66
14. Synthèse managériale et recommandations finales 67
14.1 Résumé exécutif 67
14.2 Priorités stratégiques de sécurisation 67
14.3 Bénéfices attendus 68
Glossaire 69

1. Introduction et contexte

1.1 Contexte client

SMARTFACTORY est une entreprise industrielle multi-sites dont l'activité dépend fortement de son système d'information. Celui-ci soutient la production, la logistique inter-sites, l'ERP, l'authentification, les échanges internes et la gestion de données sensibles. La disponibilité et l'intégrité du SI conditionnent donc directement la continuité des opérations.

L'environnement étudié présente plusieurs facteurs de risque : hétérogénéité technique, systèmes partiellement obsolètes, sécurisation non homogène et dépendance à des services centraux. Dans ce contexte, les menaces les plus structurantes sont le ransomware, le phishing, la compromission de comptes à privilèges et la fuite de données sensibles.

La sécurisation du SI constitue ainsi un enjeu opérationnel et stratégique, à la fois pour limiter les interruptions d'activité, protéger les données critiques et améliorer la résilience globale de l'entreprise.

1.2 Objet de la mission

La mission consiste à produire une démarche de sécurisation cohérente, fondée sur l'analyse de l'existant, l'identification des écarts, l'étude des risques et la définition d'une trajectoire de remédiation.

L'objectif n'est pas seulement de corriger des failles ponctuelles, mais de proposer un plan de sécurisation exploitable, priorisé et adapté aux enjeux techniques, organisationnels et métiers de SMARTFACTORY. Ce livrable doit permettre d'éclairer les décisions de sécurisation, de structurer les projets à conduire et de renforcer la capacité de l'entreprise à prévenir, détecter et gérer un incident cyber.

1.3 Périmètre étudié

L'étude porte sur l'ensemble du système d'information de SMARTFACTORY dans une logique globale. Le périmètre comprend les sites de l'entreprise, leurs interconnexions, l'infrastructure réseau, les serveurs, les accès utilisateurs et administrateurs, les services cloud, les mécanismes de sauvegarde, les outils de supervision et les applications critiques.

L'analyse intègre également les dimensions organisationnelles de la sécurité, notamment la gouvernance, la continuité d'activité, la gestion de crise et le pilotage des actions de sécurisation. L'objectif est de relier les constats observés aux risques métier, puis aux mesures de protection à prioriser.

1.4 Méthodologie

La démarche retenue s'articule en quatre étapes : audit de l'existant, analyse des écarts, analyse de risques selon EBIOS Risk Manager, puis définition d'une architecture cible et d'un plan de remédiation.

Cette approche vise à relier les constats techniques, les impacts métier et les décisions de sécurisation à prendre. Elle combine donc des dimensions techniques, organisationnelles et décisionnelles afin de produire des recommandations cohérentes avec les enjeux de SMARTFACTORY.

2. Méthodologie d'audit et référentiels retenus

2.1 Démarche d'audit

L'audit de sécurité a été conduit selon une démarche structurée afin d'identifier les faiblesses du système d'information, d'en évaluer les conséquences et de hiérarchiser les mesures de remédiation.

La démarche comprend une phase de cadrage, une phase de collecte d'informations sur les composants du SI, une analyse des écarts par rapport aux bonnes pratiques, puis une analyse de risques permettant de relier les vulnérabilités observées aux impacts potentiels sur l'activité. L'audit débouche enfin sur des recommandations priorisées servant de base au plan de sécurisation.

2.2 Référentiels et bonnes pratiques

L'analyse s'appuie sur plusieurs référentiels complémentaires. Les normes ISO 27001 et ISO 27002 structurent l'approche de gouvernance, de gestion des accès, de journalisation, de gestion des incidents et de continuité d'activité. Les recommandations de l'ANSSI apportent un cadre opérationnel pour le durcissement, l'authentification forte, la segmentation réseau, la gestion des comptes à privilèges et la sécurisation des sauvegardes.

Le RGPD est mobilisé pour les enjeux de protection des données, de contrôle d'accès, de traçabilité et de gestion des violations. COBIT complète l'analyse sous l'angle du pilotage, du suivi des écarts et de l'alignement entre sécurité et objectifs métier. L'usage combiné de ces référentiels permet de justifier les constats, de qualifier les écarts et d'appuyer les recommandations proposées.

2.3 Critères d'analyse

Les critères d'analyse ont été définis pour évaluer de manière homogène les composants du système d'information. Ils portent principalement sur la gestion des accès, la segmentation réseau, l'obsolescence des systèmes, la gestion des correctifs, la journalisation, la supervision, la sauvegarde, la continuité d'activité et la gouvernance.

Ces critères permettent d'identifier les faiblesses les plus structurantes du SI, de qualifier leur niveau de criticité et de construire un plan d'action cohérent avec les risques et les exigences de sécurité applicables.

3. Audit de l'existant et analyse des écarts

3.1 Vue d'ensemble de l'infrastructure actuelle

L'infrastructure actuelle de SMARTFACTORY repose sur un modèle hybride combinant ressources locales et services cloud. Le système d'information s'appuie sur quatre sites interconnectés, des serveurs assurant les fonctions critiques, des postes utilisateurs répartis sur les sites, des services de messagerie et de collaboration, ainsi que des mécanismes de sauvegarde.

Cette organisation apporte de la souplesse et de la disponibilité, mais elle n'est pas accompagnée d'un niveau de sécurisation homogène. Les principales faiblesses observées concernent la segmentation réseau, la gestion des accès, la supervision et la résilience. Ces constats justifient l'analyse détaillée présentée dans les sections suivantes.

3.2 Analyse par domaine

L'analyse de l'existant est structurée par grands domaines fonctionnels afin d'identifier les principaux écarts de sécurité et leurs impacts potentiels sur l'activité. Cette approche permet de relier chaque faiblesse observée à un risque concret, puis aux mesures de remédiation à prioriser.

3.2.1 Systèmes et serveurs

Les systèmes et serveurs assurent des fonctions critiques telles que l'authentification, le stockage de données et l'exécution des applications métiers. L'analyse met en évidence une hétérogénéité des environnements, la présence de composants proches de l'obsolescence et un durcissement non homogène. Les mises à jour ne sont pas appliquées de manière suffisamment structurée, ce qui augmente l'exposition aux vulnérabilités connues.

Ces constats font des serveurs et des systèmes un périmètre prioritaire, car ils concentrent des fonctions critiques et représentent une surface d'attaque importante.

Élément	***Situation actuelle***	***Risque***
Versions OS	Hétérogènes	Vulnérabilités
Mises à jour	Non uniformes	Failles exploitées
Durcissement	Partiel	Surface d'attaque élevée

3.2.2 Réseau et interconnexion

Le réseau constitue un point structurant du système d'information, mais son niveau de cloisonnement reste insuffisant. La segmentation entre les zones utilisateurs, serveurs, administration et services critiques est limitée, ce qui facilite la propagation d'un incident. Les flux internes et inter-sites sont encore peu documentés et le filtrage ne permet pas toujours un contrôle suffisamment fin des communications.

Dans cet état, le réseau ne réduit pas suffisamment le risque de mouvement latéral et complique la détection d'un comportement anormal.

Élément	***Situation actuelle***	***Risque***
Segmentation	Faible	Propagation attaque
Filtrage	Partiel	Accès non contrôlé
Flux	Peu documentés	Manque de visibilité

3.2.3 Identités et accès

La gestion des identités et des accès constitue un point de fragilité majeur. L'authentification multifacteur n'est pas généralisée, certains comptes disposent de privilèges élevés sans contrôle suffisant et la gestion des habilitations n'est pas assez formalisée. Cette situation augmente le risque de compromission de comptes, d'abus de privilèges et d'actions non tracées sur des ressources sensibles.

Le renforcement des accès doit donc être considéré comme une priorité immédiate, en particulier pour les comptes sensibles et d'administration.

Élément	*Situation actuelle*	*Risque*
MFA	Partiel	Compromission comptes
Droits	Peu maîtrisés	Abus de privilèges
Comptes admin	Nombreux	Élévation de privilèges

3.2.4 Sauvegarde et restauration

Des mécanismes de sauvegarde existent, mais leur niveau de résilience reste insuffisant face à une crise cyber. Les sauvegardes demeurent trop dépendantes de l'environnement principal, leur isolement est limité et les tests de restauration ne sont pas assez réguliers. Dans un scénario de type ransomware, cette situation peut compromettre la capacité réelle de reprise.

La fiabilité du dispositif ne dépend donc pas seulement de l'existence de sauvegardes, mais de leur isolement, de leur testabilité et de leur aptitude à soutenir un rétablissement effectif des services critiques.

Élément	*Situation actuelle*	*Risque*
Sauvegarde	Centralisée	Compromission globale
Tests	Rares	Restauration incertaine
Isolation	Faible	Ransomware

3.2.5 Supervision, détection et logs

La supervision actuelle permet surtout un suivi technique de disponibilité, mais reste insuffisante sur le plan de la détection sécurité. La journalisation n'est ni homogène ni centralisée sur l'ensemble du périmètre, et l'absence de corrélation structurée des événements réduit la capacité de détection et complique l'investigation. Les délais d'identification d'un incident s'en trouvent allongés, en particulier sur les composants critiques.

Le besoin n'est donc pas uniquement d'augmenter le volume de journaux collectés, mais de disposer d'une visibilité exploitable, centralisée et orientée détection.

Élément	*Situation actuelle*	*Risque*
Logs	Dispersés	Détection tardive
SIEM	Absent	Manque de corrélation
Supervision	Basique	Faible visibilité

3.2.6 Données et applications critiques

Les données et les applications critiques, notamment l'ERP, l'annuaire et les services métiers centraux, sont au cœur du fonctionnement de SMARTFACTORY. Leur niveau de protection reste toutefois hétérogène, les

données sensibles sont peu classifiées, les contrôles d'accès sont perfectibles et certains composants critiques ne sont pas suffisamment isolés. Cette situation expose l'entreprise à des risques de fuite, d'altération ou d'interruption de services essentiels.

La protection des données ne doit donc pas être abordée uniquement sous l'angle technique, mais aussi sous l'angle de la maîtrise des accès, de la traçabilité et de la classification.

Élément	***Situation actuelle***	***Risque***
ERP	Critique	Arrêt production
Données	Peu classifiées	Fuite
Accès	Large	Exposition

3.2.7 Gouvernance et organisation

L'analyse met en évidence un niveau de formalisation encore insuffisant sur les volets de gouvernance, de rôles, de procédures et de pilotage. Les responsabilités en matière de sécurité sont encore partiellement définies, les procédures ne couvrent pas toujours l'ensemble des situations critiques et les indicateurs de suivi restent incomplets. Cette situation réduit la capacité de l'organisation à piloter durablement la sécurité et à arbitrer les priorités.

La sécurisation du SI suppose donc non seulement des mesures techniques, mais aussi un cadre de gouvernance permettant de suivre les écarts, les risques, les actions et les résultats.

Élément	***Situation actuelle***	***Risque***
Procédures	Absentes	Mauvaise gestion crise
Rôles	Flous	Inefficacité
Pilotage	Limité	Manque de suivi

3.3. Tableau des écarts majeurs

Ce tableau présente les principaux écarts identifiés lors de l'audit du système d'information, en les comparant aux bonnes pratiques et référentiels de sécurité, ainsi que les risques associés et leur niveau de criticité.

Domaine	***Constat***	***Référence / bonne pratique attendue***	***Écart***	***Risque***	***Niveau de criticité***
Réseau	Absence de segmentation entre les différentes zones (utilisateurs,	ANSSI - Cloisonnement réseau / ISO 27002	Oui	Propagation rapide d'une attaque (mouvement latéral)	**Critique**

	serveurs, administration)				
Réseau	Flux réseau non documentés et peu contrôlés	ANSSI - Maîtrise des flux	Oui	Accès non autorisés, difficulté de détection	**Critique**
Systèmes	Présence de systèmes obsolètes ou non maintenus	ISO 27002 - Gestion des vulnérabilités	Oui	Exploitation de failles connues	**Critique**
Systèmes	Absence de politique de durcissement homogène	ANSSI - Durcissement des systèmes	Oui	Augmentation de la surface d'attaque	**Haute**
Accès	MFA non généralisé	ISO 27001 / ANSSI - Authentification forte	Oui	Compromission de comptes (phishing)	**Critique**
Accès	Comptes à privilèges trop nombreux	Principe du moindre privilège	Oui	Escalade de privilèges	**Critique**
Accès	Gestion des habilitations non formalisée	ISO 27002 - Gestion des accès	Oui	Accès non justifiés	**Haute**
Sauvegarde	Sauvegardes non isolées du SI	ANSSI - Sauvegarde sécurisée	Oui	Chiffrement/destruction des sauvegardes (ransomware)	**Critique**
Sauvegarde	Tests de restauration non réguliers	ISO 27002 - Continuité d'activité	Oui	Données non restaurables	**Haute**
Supervision	Absence de SIEM / corrélation des logs	Bonnes pratiques SOC	Oui	Détection tardive d'incidents	**Critique**
Supervision	Journalisation partielle	ISO 27002 - Journalisation	Oui	Manque de traçabilité	**Haute**
Données	Données sensibles non classifiées	ISO 27001 - Classification des données	Oui	Fuite ou mauvaise protection	**Haute**
Applications	ERP critique non suffisamment isolé	ANSSI - Protection des systèmes critiques	Oui	Arrêt de production	**Critique**

Gouvernance	Absence de politique de sécurité formalisée	ISO 27001 - SMSI	Oui	Manque de pilotage sécurité	**Critique**
Gouvernance	Rôles et responsabilités flous	Bonnes pratiques GRC	Oui	Mauvaise gestion des incidents	**Haute**
Gouvernance	Absence d'indicateurs de sécurité	GRC / Pilotage	Oui	Impossible de mesurer le niveau de sécurité	**Haute**

L'analyse des écarts met en évidence plusieurs faiblesses critiques, notamment en matière de segmentation réseau, de gestion des accès et de supervision. Ces éléments constituent des points d'entrée privilégiés pour des attaques et devront être traités en priorité dans le plan de sécurisation.

3.3.1 Traçabilité des constats d'audit

Afin de renforcer la traçabilité de l'audit, les principaux écarts ont été rapprochés d'éléments observés, de risques associés et d'un niveau de criticité. Cette lecture permet de montrer que les recommandations proposées dans la suite du document découlent directement des constats formulés sur l'environnement étudié.

Domaine	***Constat***	***Élément observé***	***Risque principal***	***Criticité***
Accès	MFA non généralisé	Protection incomplète des comptes sensibles	Compromission de comptes	Critique
Réseau	Segmentation insuffisante	Cloisonnement limité entre zones	Propagation latérale	Critique
Systèmes	Durcissement hétérogène	Maintien en condition de sécurité non uniforme	Exploitation de vulnérabilités connues	Haute
Sauvegarde	Sauvegardes peu isolées	Dépendance excessive à l'environnement principal	Ransomware / perte de restauration	Critique
Supervision	Corrélation absente	Logs dispersés et visibilité réduite	Détection tardive	Critique
Gouvernance	Pilotage incomplet	Procédures et indicateurs partiels	Difficulté de suivi et de décision	Haute

4. Exigences de sécurité, obligations et niveau de conformité

4.1 Exigences applicables

4.1.1 Traçabilité, journalisation et supervision

La journalisation et la supervision constituent une exigence structurante de la sécurité du système d'information. Tous les composants sensibles du SI doivent produire des journaux exploitables, horodatés de manière cohérente et conservés selon une durée définie. Les événements liés aux authentifications, aux changements de privilèges, aux actions d'administration, aux accès aux données sensibles et aux modifications de configuration doivent être tracés. Ces journaux doivent être centralisés dans une plateforme de supervision capable d'assurer leur conservation, leur corrélation et leur mise à disposition pour l'investigation. L'exigence porte donc sur quatre dimensions : la couverture des sources, la cohérence temporelle, la centralisation sécurisée et la production d'alertes exploitables.

4.1.2 Sauvegarde et résilience

La sauvegarde est une exigence de résilience majeure, car elle conditionne directement la capacité de reprise après incident. Dans le contexte étudié, le dispositif attendu doit reposer sur des sauvegardes isolées, supervisées et régulièrement testées. Une logique de type 3-2-1, associée à une séparation des droits d'administration et à des exercices de restauration, permet de réduire le risque de perte simultanée des systèmes de production et des mécanismes de reprise.

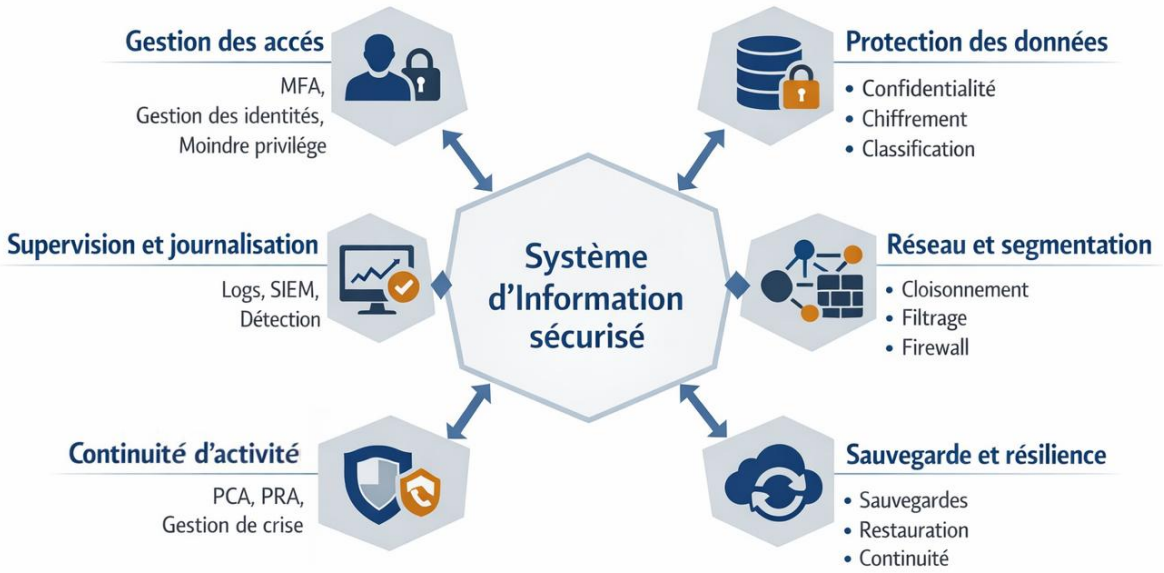
Une sauvegarde non isolée ou non testée ne constitue pas une garantie de résilience suffisante face à un incident cyber majeur.

4.1.3 Séparation des environnements et segmentation

La segmentation du système d'information vise à réduire la surface d'attaque et à limiter la propagation d'un incident. Les postes utilisateurs, les serveurs, les environnements d'administration, les sauvegardes et les services critiques ne doivent pas cohabiter dans un espace réseau unique. Les flux entre zones doivent être autorisés uniquement lorsqu'ils répondent à un besoin identifié, selon une logique de filtrage restrictif.

Dans le cas de SMARTFACTORY, cette exigence est directement liée au risque de mouvement latéral, à la protection de l'ERP et à la capacité de contenir une compromission initiale.

4.2. Analyse de conformité



L'analyse de conformité a pour objectif de rapprocher les exigences applicables du niveau réel de maîtrise observé sur le périmètre étudié. Elle permet d'identifier les domaines dans lesquels les mesures de sécurité sont insuffisantes, de prioriser les écarts et de transformer les obligations en actions de mise en conformité suivies dans le temps.

Dans le cadre de SMARTFACTORY, les écarts les plus structurants concernent la gestion des accès, la journalisation, la protection des données, la segmentation, les sauvegardes et le pilotage. L'analyse qui suit vise donc moins à documenter la théorie des référentiels qu'à organiser un plan d'action cohérent avec les priorités de sécurité identifiées.

4.2.1. Matrice de conformité et plan de mise en conformité

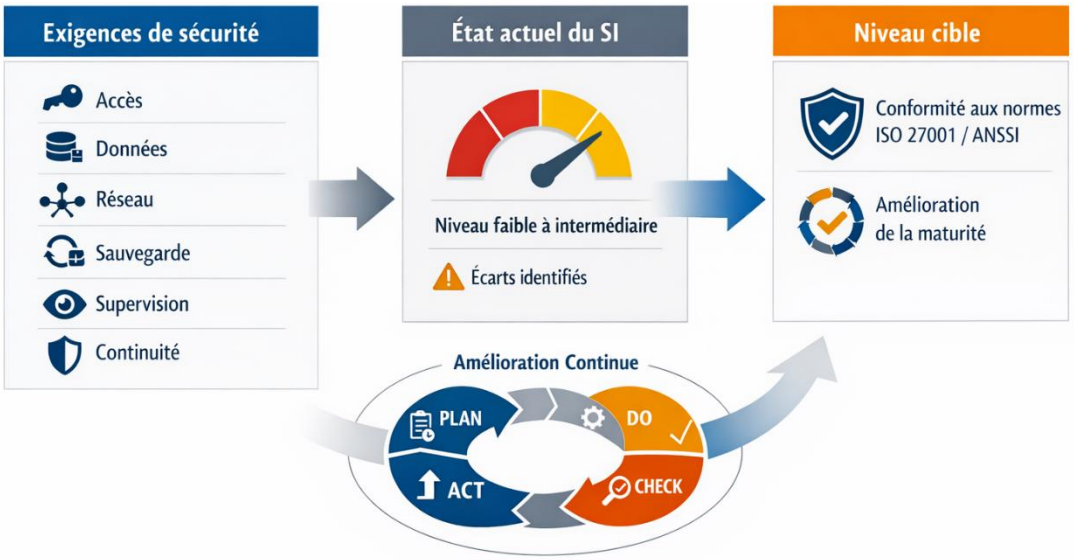
Référentiel	***Domaine clé***	***Niveau estimé***	***Écart principal***	***Priorité***
RGPD	Accès aux données, journalisation, violation de données	Partiel	Habilitations et traçabilité à renforcer	Haute
ISO 27001 / 27002	Accès, journalisation, incidents, continuité	Partiel	Formalisation et contrôle insuffisants	Haute
ANSSI	MFA, segmentation, sauvegardes, comptes à privilèges	Partiel	Mesures techniques à renforcer	Haute
COBIT	Gouvernance et suivi	Partiel	Pilotage des écarts à structurer	Moyenne

Au-delà de la matrice de synthèse, la mise en conformité doit être traduite en actions concrètes, planifiées et suivies dans le temps. Pour SMARTFACTORY, les écarts identifiés portent principalement sur la maîtrise des accès, la traçabilité, la protection des données, la résilience et la gouvernance. Le plan ci-dessous vise à structurer les actions prioritaires à engager afin d'atteindre un niveau de conformité cohérent avec les exigences du RGPD, des normes ISO 27001/27002, des recommandations de l'ANSSI et des principes de gouvernance issus de COBIT.

Exigence / référentiel	**Écart constaté**	**Action de mise en conformité**	**Responsable**	**Échéance**	**Preuve attendue**
RGPD - contrôle d'accès aux données personnelles	Gestion des habilitations non formalisée, droits excessifs sur certaines ressources	Formaliser une procédure d'habilitation, mettre en place une revue trimestrielle des droits, appliquer le principe du moindre privilège	RSSI / DSI / RH	Court terme	Procédure validée, comptes revus, historique des revues de droits
RGPD - traçabilité et détection des accès	Journalisation partielle sur les systèmes et applications critiques	Étendre la journalisation aux systèmes sensibles, centraliser les logs, définir une durée de conservation cohérente	DSI / Administrateur systèmes	Court terme	Politique de journalisation, journaux centralisés, preuves de conservation
RGPD - gestion des violations de données	Procédure de détection et d'escalade insuffisamment formalisée	Formaliser une procédure de gestion des violations de données incluant qualification, notification interne, analyse d'impact et escalade	RSSI / DPO / Direction	Court terme	Procédure de violation de données, modèle de fiche incident, circuit d'escalade

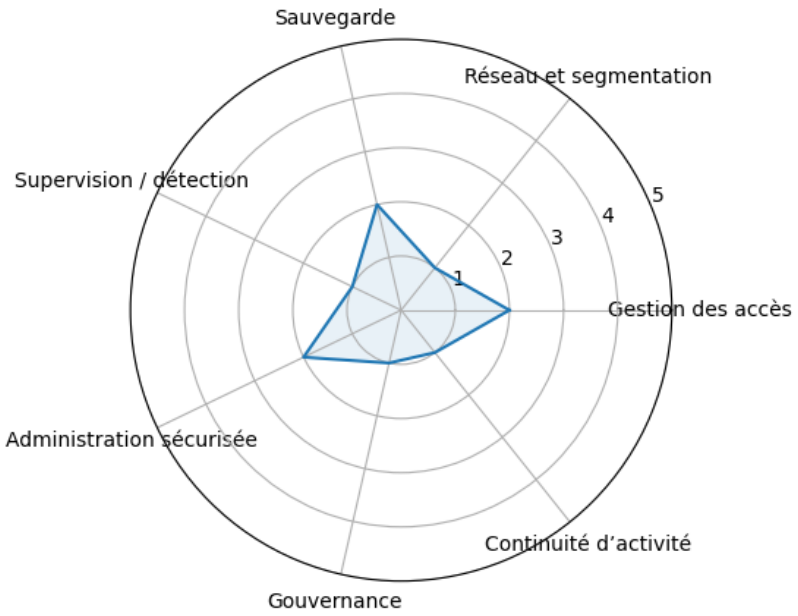
ISO 27001 / 27002 - gestion des accès	MFA non généralisé et séparation des comptes insuffisante	Déployer le MFA sur tous les comptes sensibles, séparer comptes utilisateurs et comptes d'administration	DSI / RSSI	Court terme	Comptes protégés par MFA, politique d'administration, rapports de déploiement
ISO 27001 / 27002 - gestion des incidents	Gestion encore peu outillée, supervision insuffisante	Mettre en place un SIEM, formaliser le processus de traitement des incidents, définir les niveaux de criticité	RSSI / Équipe sécurité	Moyen terme	Procédure incident, cas d'usage SIEM, tableaux de suivi
ISO 27001 / 27002 - continuité et reprise	PRA et tests de restauration insuffisamment formalisés	Formaliser le PRA, définir l'ordre de reprise, planifier des tests de restauration semestriels	DSI / RSSI	Moyen terme	PRA validé, comptes rendus de tests, planning de tests
ANSSI - cloisonnement et maîtrise des flux	Absence de segmentation suffisante, flux peu documentés	Mettre en place les VLAN cibles, documenter les flux autorisés, appliquer des règles de filtrage inter-zones	Architecte réseau / DSI	Court terme	Schéma réseau cible, matrice de flux, règles firewall validées
ANSSI - sécurisation des comptes à privilèges	Trop de comptes privilégiés, supervision limitée des actions d'administration	Réduire le nombre de comptes à privilèges, mettre en place un bastion, tracer les actions d'administration	RSSI / DSI	Moyen terme	Inventaire des comptes admin, bastion déployé, journaux d'administration
ANSSI - sauvegardes sécurisées	Sauvegardes non isolées et tests non réguliers	Appliquer une stratégie 3-2-1, isoler une copie hors ligne ou immuable, tester régulièrement la restauration	DSI / Responsable infrastructure	Court terme	Politique de sauvegarde, preuve d'isolement, rapports de test
ISO 27001 / RGPD - protection des données sensibles	Données sensibles peu classifiées et protection hétérogène	Mettre en place une classification des données, des règles de protection adaptées et un suivi des accès aux données sensibles	RSSI / DPO / Métiers	Moyen terme	Politique de classification, inventaire des données sensibles, règles de protection
COBIT - gouvernance et pilotage	Pilotage sécurité encore peu formalisé	Mettre en place un suivi des risques, des écarts, des actions et des indicateurs dans un outil GRC	RSSI / Direction / DSI	Moyen terme	Registre des risques, tableau de bord, plan d'actions suivi
COBIT - audit et amélioration continue	Absence de cycle de revue structuré	Planifier des audits périodiques, des revues de conformité et une réévaluation annuelle des risques	RSSI / Audit interne	Long terme	Plan d'audit, comptes rendus de revue, plan d'amélioration continue

4.3. Niveau de maturité



L'évaluation de la maturité met en évidence un niveau global faible à intermédiaire, avec des lacunes importantes sur les domaines critiques tels que la segmentation réseau, la détection des incidents et la gouvernance.

La progression attendue repose sur la mise en œuvre priorisée des mesures de sécurisation, le suivi des écarts et la formalisation du pilotage sécurité.



5. Analyse de risques avec la méthode EBIOS Risk Manager

5.1. Atelier 1 - Cadrage et socle

L'atelier 1 de la méthode EBIOS Risk Manager vise à définir le périmètre de l'étude, identifier les valeurs métier, les biens supports ainsi que les événements redoutés associés. Cette étape constitue le socle de l'analyse de risques et conditionne la pertinence des ateliers suivants.

5.1.1. Périmètre de l'étude

Le périmètre de l'étude concerne le système d'information de l'organisation, incluant :

- les utilisateurs internes (employés, administrateurs)
- les services métiers (ERP, applications internes)
- les infrastructures techniques (serveurs, réseau, Active Directory)
- les accès distants (VPN, accès cloud)
- les interactions avec des prestataires externes

L'objectif est d'assurer la sécurité des accès au système d'information en garantissant la confidentialité, l'intégrité et la disponibilité des données.

5.1.2. Valeur métier

Dans le contexte de SMARTFACTORY, les valeurs métier ne doivent pas être formulées comme de simples éléments de sécurité ou de gouvernance. Elles doivent refléter les activités et informations dont dépend directement le fonctionnement de l'entreprise.

SMARTFACTORY étant une entreprise industrielle répartie sur plusieurs sites et fortement dépendante de son ERP, de ses échanges inter-sites et de ses données sensibles, les valeurs métier retenues sont les suivantes :

Valeur métier	***Type***	***Description***
Produire et maintenir la fabrication des composants techniques	Processus	Assurer l'exécution des opérations industrielles sur les différents sites sans interruption majeure
Livrer et coordonner la logistique inter-sites	Processus	Garantir la circulation des flux, des informations et des ressources entre les sites de l'entreprise
Gérer les achats et l'approvisionnement	Processus	Assurer la continuité des commandes, des relations fournisseurs et de la disponibilité des composants nécessaires à la production
Gérer la facturation et les opérations administratives	Processus	Maintenir les fonctions de gestion, de suivi administratif et de traitement financier via l'ERP et les outils métiers
Protéger les données sensibles de l'entreprise	Information	Préserver la confidentialité, l'intégrité et la disponibilité des données clients, RH, financières et techniques
Maintenir la continuité opérationnelle multi-sites	Processus	Garantir la poursuite de l'activité malgré un incident affectant les accès, le réseau, l'ERP ou les services centraux

5.1.3. Biens essentiels

À partir de ces valeurs métier, les biens essentiels ont été identifiés comme les informations, traitements et services critiques directement nécessaires au fonctionnement de l'entreprise. Ils constituent les éléments dont l'atteinte aurait un impact direct sur l'activité, avant même d'analyser les biens supports techniques.

Valeur métier	***Biens essentiels associés***	***Justification***
Produire et maintenir la fabrication des composants techniques	Ordres de fabrication, données de production, paramétrages métiers, applications de pilotage de production	Sans ces éléments, la production ne peut plus être exécutée correctement
Livrer et coordonner la logistique inter-sites	Données logistiques, informations d'expédition, flux de coordination inter-sites, suivi des mouvements	Leur indisponibilité ou altération désorganise la circulation des flux et les échanges entre sites
Gérer les achats et l'approvisionnement	Données fournisseurs, commandes d'achat, niveaux de stock, informations d'approvisionnement	Ces éléments conditionnent la capacité à alimenter la production et à éviter les ruptures

Gérer la facturation et les opérations administratives	Données de gestion, données comptables, informations clients, factures, historiques administratifs	Leur altération ou indisponibilité bloque une partie des fonctions de gestion et crée des impacts financiers
Protéger les données sensibles de l'entreprise	Données clients, données RH, données financières, documents techniques et contractuels	Ces données exposent l'entreprise à des impacts réglementaires, financiers et réputationnels
Maintenir la continuité opérationnelle multi-sites	ERP, interconnexions entre sites, services d'authentification, messagerie, sauvegardes	Ces services conditionnent la capacité de l'entreprise à continuer à fonctionner en mode nominal ou dégradé

5.1.4. Biens supports

Les biens essentiels identifiés précédemment reposent sur des biens supports techniques, humains, physiques et organisationnels. Leur compromission peut permettre à une source de risque d'atteindre indirectement les valeurs métier de SMARTFACTORY.

Les biens supports sont les éléments techniques, humains et organisationnels permettant le fonctionnement des valeurs métier.

Ils constituent les points d'entrée potentiels pour les attaques, car les scénarios opérationnels s'appuient sur leur compromission.

Conformément à l'ANSSI, les biens supports sont classés comme suit :

Systèmes informatiques :

- Serveurs (Active Directory, bases de données)
- Postes de travail
- Applications métier (ERP, CRM)
- Systèmes d'exploitation

Réseaux et communications :

- Équipements réseau (switch, routeur)
- Accès Internet / VPN
- Wi-Fi
- DNS / DHCP

Sécurité et administration :

- Firewall
- SIEM
- Outils d'administration
- Bastion

Facteur humain :

- Utilisateurs
- Administrateurs
- Prestataires
- Personnel interne

Physique et environnement :

- Salles serveurs
- Locaux
- Contrôle d'accès physique
- Alimentation électrique

Organisation et information :

- Procédures internes
- Documentation
- Données papier
- Échanges verbaux

5.1.5. Événements redoutés

Les événements redoutés correspondent aux atteintes redoutées sur les valeurs métier et les biens essentiels. Ils doivent être formulés en termes d'impact métier pour l'organisation, et non uniquement en termes techniques. Dans le cadre de SMARTFACTORY, les principaux événements redoutés identifiés sont les suivants :

Valeur métier	***Événement redouté***	***Impacts métier principaux***
Produire et maintenir la fabrication des composants techniques	Indisponibilité ou chiffrement des données et applications de production	Arrêt ou ralentissement de la production, retards de livraison, pertes financières
Livrer et coordonner la logistique inter-sites	Interruption des flux logistiques ou rupture des échanges inter-sites	Désorganisation opérationnelle, isolement d'un ou plusieurs sites, retards dans les opérations
Gérer les achats et l'approvisionnement	Altération ou indisponibilité des données d'approvisionnement	Erreurs de commande, rupture de stock, tensions sur la chaîne de production
Gérer la facturation et les opérations administratives	Altération ou indisponibilité des données de gestion et de facturation	Blocage administratif, erreurs de traitement, dégradation du suivi financier
Protéger les données sensibles de l'entreprise	Accès non autorisé, fuite ou exfiltration de données sensibles	Atteinte à l'image, perte de confiance, risque réglementaire et contractuel

Maintenir la continuité opérationnelle multi-sites	Compromission des accès critiques ou indisponibilité généralisée des services centraux	Perte de maîtrise du SI, interruption multi-sites, incapacité à administrer ou à redémarrer rapidement

5.1.6. Évaluation de la gravité

L'évaluation de la gravité vise à mesurer les conséquences potentielles d'un événement redouté sur l'activité de SMARTFACTORY. L'échelle retenue est la suivante :

Niveau	***Description***
G1	Mineur
G2	Significatif
G3	Grave
G4	Critique
G5	Catastrophique

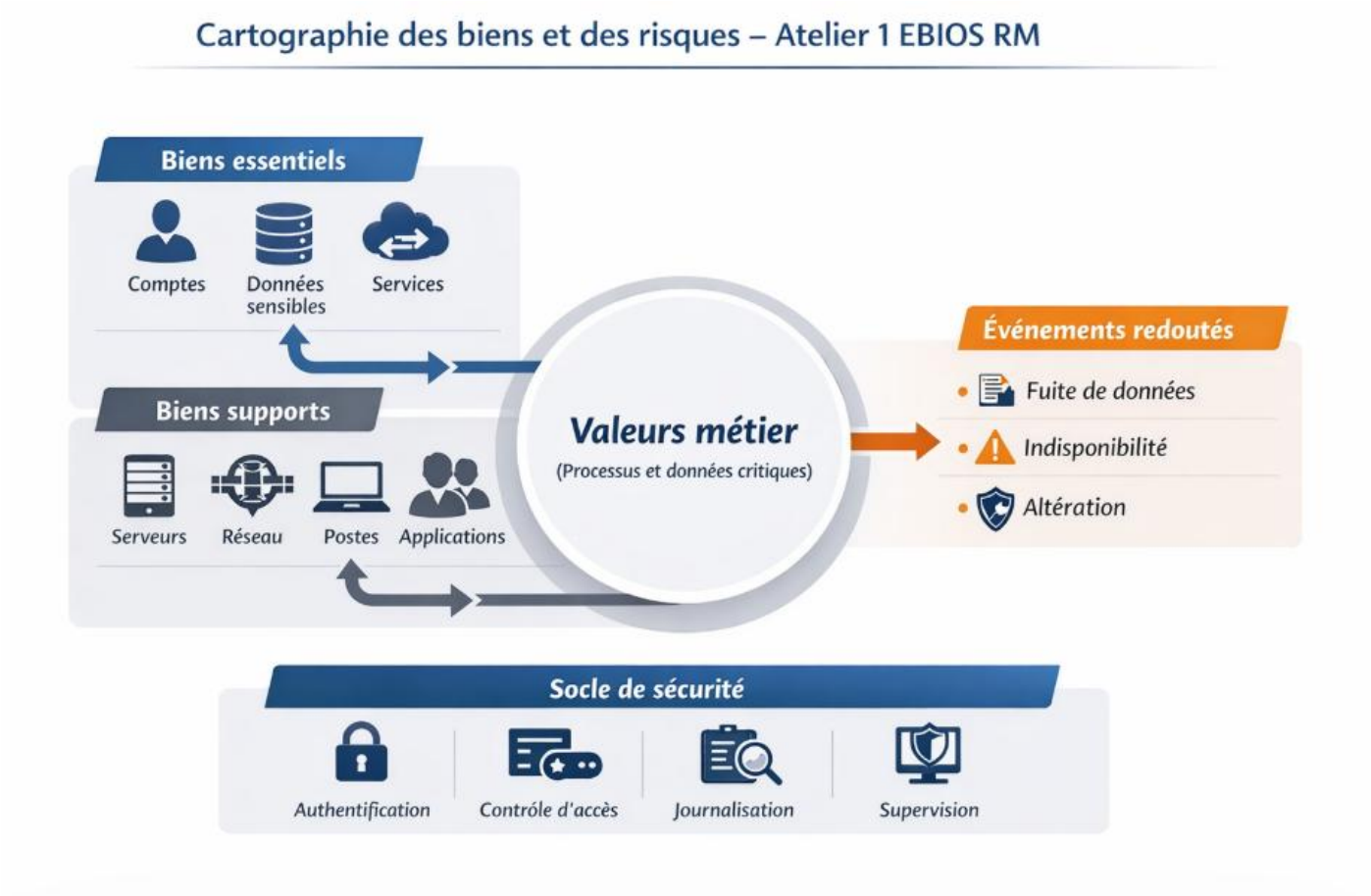
Au-delà de cette échelle, il est nécessaire d'attribuer un niveau de gravité à chaque événement redouté identifié.

Événement redouté	***Gravité***	***Justification***
Indisponibilité ou chiffrement des données et applications de production	G5 - Catastrophique	Impact direct sur la production industrielle, arrêt potentiel sur plusieurs sites, effet immédiat sur l'activité
Interruption des flux logistiques ou rupture des échanges inter-sites	G4 - Critique	Désorganisation forte des opérations, isolement possible d'un site, retards significatifs
Altération ou indisponibilité des données d'approvisionnement	G3 - Grave	Impact important sur la planification et la disponibilité des ressources, mais avec effet parfois différé
Altération ou indisponibilité des données de gestion et de facturation	G3 - Grave	Blocage administratif et financier important, sans arrêt immédiat de toute la production dans tous les cas
Accès non autorisé, fuite ou exfiltration de données sensibles	G4 - Critique	Impact réputationnel, réglementaire et contractuel majeur, avec conséquences durables
Compromission des accès critiques ou indisponibilité généralisée des services centraux	G5 - Catastrophique	Perte de contrôle du SI, effet systémique, impact transverse sur l'ensemble des activités de l'entreprise

Cette évaluation montre que les événements les plus critiques concernent la perte de disponibilité des processus de production, la compromission des accès critiques et les fuites de données sensibles. Ces résultats justifient la priorité donnée, dans la suite du document, à la sécurisation des accès, à la segmentation, à la supervision et à la résilience.

5.1.7. Socle de sécurité existant

Le socle de sécurité existant comprend plusieurs mesures déjà en place, mais encore incomplètes ou hétérogènes : authentification par mot de passe, MFA partiel, gestion des droits, journalisation partielle, firewall, sauvegardes et supervision technique limitée. Ce socle sert de point de départ pour évaluer le niveau d'exposition du SI dans les ateliers suivants.



5.2. Atelier 2 - Sources de risque

L'atelier 2 de la méthode EBIOS Risk Manager consiste à identifier les sources de risque, c'est-à-dire les acteurs susceptibles de porter atteinte aux biens essentiels du système d'information.

Ces sources de risque peuvent être internes ou externes à l'organisation et se caractérisent par leurs capacités, leurs motivations et leurs modes opératoires. Cette étape permet de mieux comprendre les menaces afin de construire des scénarios réalistes dans les ateliers suivants.

5.2.1. Typologie des sources de risque

Dans le contexte de SMARTFACTORY, plusieurs sources de risque ont été identifiées.

Cybercriminels

Les cybercriminels représentent une menace majeure pour les systèmes d'information. Leur objectif principal est généralement financier.

Ils exploitent des vulnérabilités techniques ou humaines pour :

- déployer des ransomwares
- voler des données sensibles
- compromettre des comptes

Capacités : élevées (outils automatisés, campagnes massives)

Motivation : gain financier

Cible : entreprises industrielles (fort impact métier)

Employés négligents

Les utilisateurs internes peuvent être à l'origine d'incidents, souvent de manière involontaire.

Exemples :

- clic sur un lien de phishing
- utilisation de mots de passe faibles
- partage d'informations sensibles

Capacités : faibles

Motivation : aucune (erreur humaine)

Risque : point d'entrée initial

Prestataires et partenaires

Les prestataires ayant accès au système d'information peuvent représenter une source de risque, notamment en cas de compromission de leur propre environnement.

Exemples :

- accès distant mal sécurisé
- comptes partagés
- absence de contrôle des accès

Capacités : variables

Motivation : indirecte

Risque : accès privilégié

Compromission de comptes

La compromission de comptes est un scénario transversal, souvent utilisé par les attaquants.

Elle peut résulter de :

- phishing
- fuite d'identifiants

- mots de passe faibles

Capacités : dépend de l'attaquant

Impact : très élevé

Risque : accès légitime au SI

Menace opportuniste

Les attaques opportunistes visent des cibles sans distinction particulière, souvent via des campagnes automatisées.

Exemples :

- scans de vulnérabilités
- attaques automatisées
- exploitation de failles connues

Capacités : automatisées

Motivation : opportuniste

Risque : exploitation rapide

5.2.2. Analyse des motivations et capacités

Source de risque	***Motivation***	***Capacités***	***Niveau de menace***
Cybercriminels	Financière	Élevées	**Très élevé**
Employés	Négligence	Faibles	**Moyen**
Prestataires	Indirecte	Moyennes	**Moyen**
Compromission compte	Variable	Élevées	**Très élevé**
Opportuniste	Opportuniste	Automatisées	**Moyen**

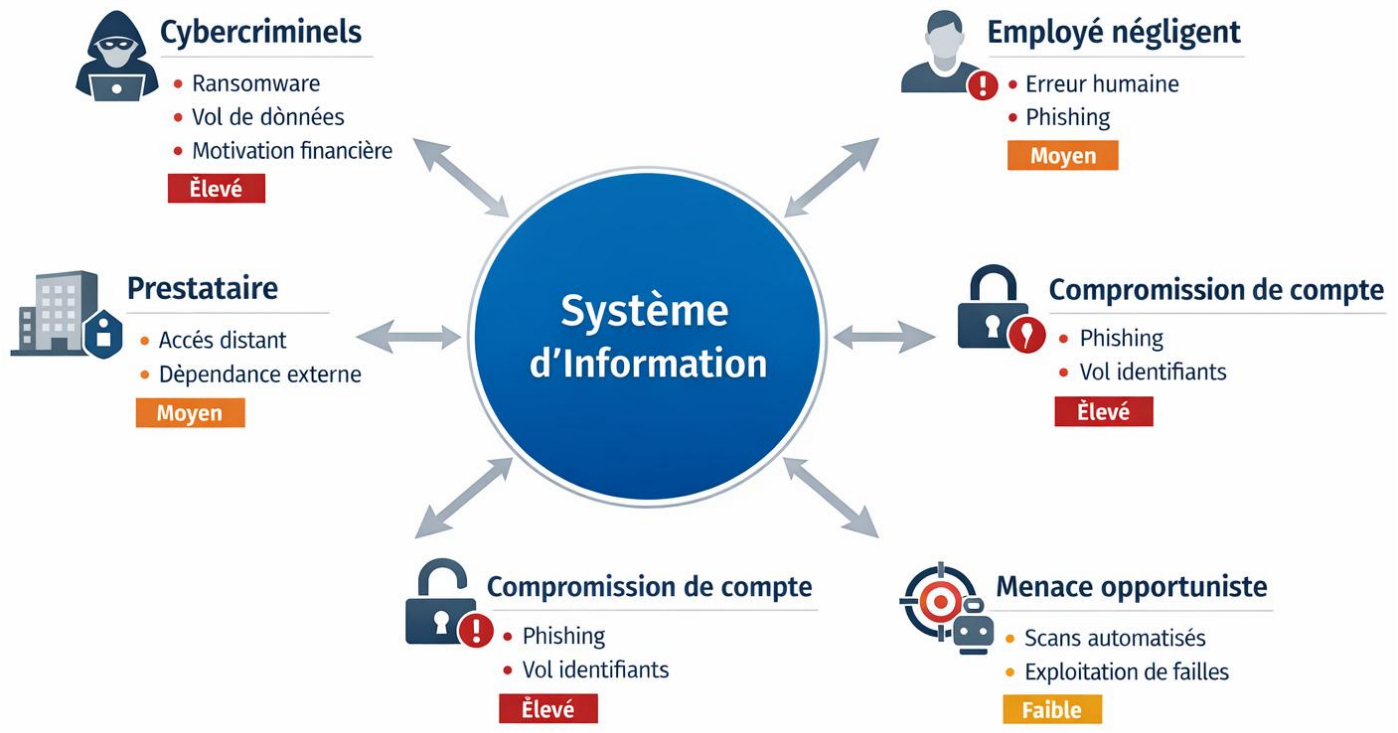
5.2.3. Positionnement des menaces

L'analyse met en évidence que les menaces les plus critiques sont celles combinant :

- forte capacité
- accès au SI
- impact métier élevé

Cela concerne principalement :

- les cybercriminels
- la compromission de comptes



5.3. Atelier 3 - Scénarios stratégiques

L'atelier 3 de la méthode EBIOS Risk Manager vise à construire des scénarios stratégiques, c'est-à-dire des situations dans lesquelles une source de risque parvient à atteindre un bien essentiel, en exploitant une vulnérabilité du système d'information.

Ces scénarios permettent d'identifier les chemins d'attaque réalistes, en croisant :

- les sources de risque (atelier 2)
- les biens essentiels (atelier 1)
- les vulnérabilités identifiées lors de l'audit

L'objectif est de prioriser les risques en fonction de leur impact sur les activités de l'entreprise.

5.3.1. Identification des scénarios stratégiques

Scénario 1 : Attaque par ransomware via phishing

Un cybercriminel envoie une campagne de phishing ciblant les utilisateurs de l'entreprise.

Un employé clique sur un lien malveillant et exécute un fichier infecté.

Le malware se propage dans le système d'information, chiffre les données et bloque l'accès aux services critiques.

Biens essentiels impactés :

- données métiers
- accès utilisateurs
- continuité d'activité

Impact :

- arrêt de production

- indisponibilité du SI
- perte financière

Gravité : Très élevée

Scénario 2 : Compromission de l'Active Directory

Un attaquant obtient les identifiants d'un compte administrateur (phishing ou brute force).

Il accède à l'Active Directory et modifie les droits d'accès.

Cela lui permet de prendre le contrôle du système d'information.

Biens essentiels impactés :

- identités
- systèmes
- données

Impact :

- contrôle total du SI
- altération des données
- impossibilité de restaurer rapidement

Gravité : Critique

Scénario 3 : Indisponibilité de l'ERP

Une panne technique ou une attaque rend l'ERP inaccessible.

Les utilisateurs ne peuvent plus accéder aux données métiers ni aux outils de production.

Biens essentiels impactés :

- ERP
- processus métiers

Impact :

- arrêt de production
- perte de productivité
- retards opérationnels

Gravité : Élevée

Scénario 4 : Fuite de données sensibles

Un utilisateur interne ou un attaquant accède à des données sensibles et les exfiltre.

Cela peut être lié à une mauvaise gestion des accès ou à un manque de supervision.

Biens essentiels impactés :

- données clients
- données internes

Impact :

- atteinte à l'image
- sanctions potentielles
- perte de confiance

Gravité : Élevée

Scénario 5 : Rupture de l'interconnexion entre sites

Une défaillance réseau ou une attaque bloque les communications entre les sites.

Les services centralisés deviennent inaccessibles.

Biens essentiels impactés :

- réseau
- services partagés

Impact :

- interruption d'activité
- isolement des sites
- dégradation des services

Gravité : Élevée

5.3.2. Analyse synthétique des scénarios

Scénario	***Source de risque***	***Impact***	***Gravité***
Ransomware	Cybercriminel	Arrêt SI	**Très élevé**
Compromission AD	Cybercriminel	Contrôle total	**Critique**
ERP indisponible	Technique / attaque	Arrêt production	**Élevé**
Fuite de données	Interne / externe	Image / RGPD	**Élevé**
Rupture réseau	Technique	Interruption	**Élevé**

5.3.3. Priorisation des scénarios

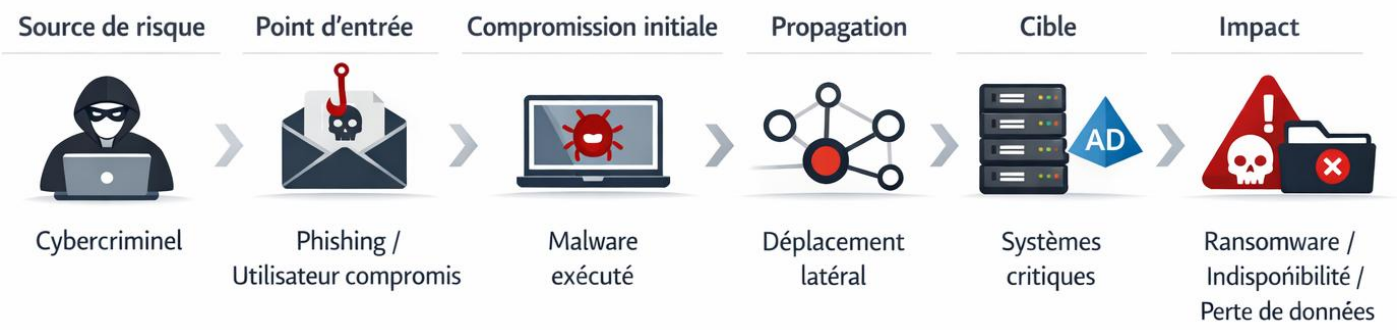
L'analyse montre que les scénarios les plus critiques sont :

- la compromission de l'Active Directory
- l'attaque par ransomware

Ces scénarios combinent :

- forte probabilité
- impact majeur
- effet systémique

Ils seront traités en priorité dans la suite de l'analyse.



5.4. Atelier 4 - Scénarios opérationnels

L'atelier 4 de la méthode EBIOS Risk Manager consiste à détailler les scénarios stratégiques identifiés précédemment, en décrivant précisément les modes opératoires des attaquants.

Chaque scénario opérationnel est analysé selon plusieurs étapes :

- point d'entrée
- progression de l'attaque
- impact
- détection
- réponse attendue

Cette approche permet d'identifier les points de faiblesse du système d'information et les mesures nécessaires pour limiter les risques.

L'ensemble des scénarios stratégiques identifiés lors de l'atelier 3 ne fait pas l'objet d'une analyse opérationnelle détaillée.

Afin de concentrer l'étude sur les risques les plus significatifs, une sélection a été réalisée en fonction de plusieurs critères :

- le niveau de criticité
- la probabilité d'occurrence
- l'impact sur les activités de l'entreprise

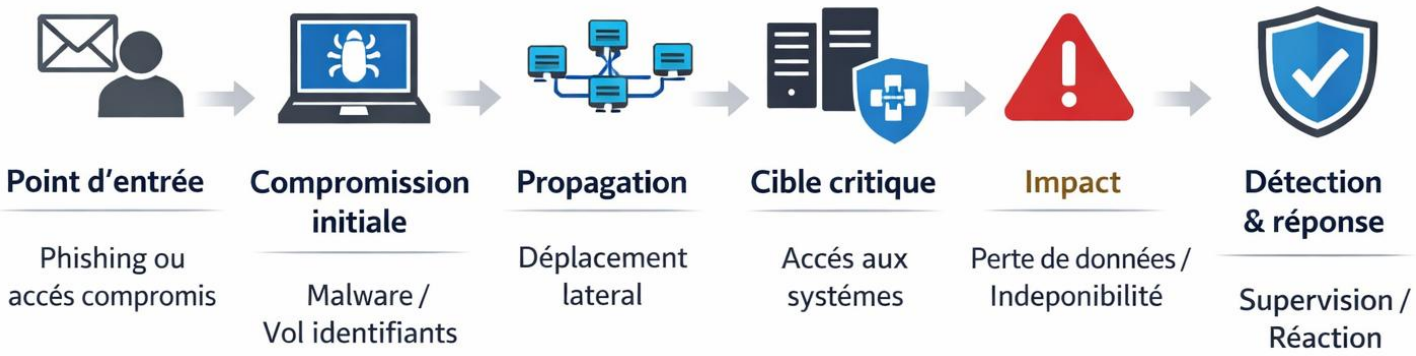
Les scénarios retenus correspondent aux menaces présentant le plus fort risque pour le système d'information, notamment :

- l'attaque par ransomware
- la compromission de l'Active Directory
- la fuite de données sensibles

Les autres scénarios, bien que pertinents, présentent un niveau de criticité moindre ou un impact plus limité et seront traités dans une approche globale de sécurisation.

Scénario	***Point d'entrée***	***Progression***	***Impact***	***Détection***	***Réponse attendue***
Ransomware via phishing	Email malveillant, utilisateur piégé	Malware → vol identifiants → propagation réseau → accès serveurs	Chiffrement des données, arrêt production, pertes financières	Détection tardive, absence de corrélation des logs	Isolement poste, coupure réseau, restauration sauvegarde, analyse
Compromission Active Directory	Identifiants admin compromis (phishing, mot de passe faible)	Accès AD → modification droits → comptes cachés → contrôle SI	Compromission globale, perte de contrôle, altération données	Activités admin peu surveillées, pas de SIEM	Désactivation comptes, audit AD, reconstruction, rotation identifiants
Fuite de données sensibles	Accès non contrôlé, droits excessifs	Extraction données → transfert externe	Fuite d'informations, atteinte image, risque RGPD	Faible traçabilité, supervision insuffisante	Analyse accès, blocage transferts, notification, renforcement contrôles

L'analyse des scénarios met en évidence des vulnérabilités critiques, notamment en matière de gestion des accès, de segmentation réseau et de supervision.



Le schéma met en évidence les différentes phases de l'attaque, ainsi que les points de détection et de réponse possibles.

Cette analyse permet d'identifier les failles exploitables et de définir les mesures de sécurité nécessaires pour limiter les risques.

5.5. Atelier 5 - Traitement des risques

L'atelier 5 de la méthode EBIOS Risk Manager vise à définir les mesures de traitement des risques identifiés lors des ateliers précédents.

Cette étape consiste à :

- évaluer le niveau de risque pour chaque scénario
- identifier les mesures de sécurité existantes
- proposer des mesures complémentaires adaptées
- prioriser les actions à mettre en œuvre

L'objectif est de construire un plan de sécurisation cohérent, permettant de réduire les risques à un niveau acceptable pour l'organisation.

5.5.1. Évaluation des risques

L'évaluation des risques repose sur deux critères principaux :

Gravité

Impact sur l'activité **:**

Niveau	***Description***
1	Faible
2	Modéré
3	Significatif
4	Élevé
5	Critique

Vraisemblance

Probabilité d'occurrence :

Niveau	***Description***
1	Très faible
2	Faible
3	Moyenne
4	Élevée
5	Très élevée

Le niveau de risque est déterminé par la combinaison des deux.

Scénario	***Gravité***	***Vraisemblance***	***Risque initial***	***Mesures complémentaires***	***Vraisemblance résiduelle***	***Risque résiduel***	***Acceptabilité***	***Priorité***
Ransomware	**5**	**4**	**Critique**	MFA, EDR, sensibilisation	**2**	**Modéré**	**Acceptable sous contrôle**	**P1**

Compromission AD	**5**	**3**	**Critique**	Bastion, MFA admin, audit	**2**	**Modéré**	**Acceptable**	**P1**
Fuite données	**4**	**3**	**Élevé**	DLP, classification	**2**	**Faible**	**Acceptable**	**P2**
ERP indispo	**4**	**3**	**Élevé**	PRA, redondance	**2**	**Faible**	**Acceptable**	**P2**
Rupture réseau	3	**3**	**Moyen**	Redondance réseau	2	**Faible**	**Acceptable**	**P3**

Après mise en œuvre des mesures de sécurité, le niveau de risque est réévalué afin de déterminer le risque résiduel.

L'objectif est de réduire la vraisemblance des scénarios et de ramener les risques à un niveau acceptable pour l'organisation.

Cette approche permet de valider la pertinence des mesures proposées et de prioriser les actions à mettre en œuvre.

L'évaluation confirme que les priorités de traitement portent d'abord sur les scénarios ayant un effet systémique sur le SI, en particulier ceux liés aux accès à privilèges, à la propagation latérale et à l'indisponibilité des services critiques.

Ces scénarios doivent être traités en priorité, notamment par la mise en place de mesures de sécurité renforcées sur les accès, la supervision et la segmentation réseau.

5.5.2. Stratégie de traitement des risques

Le traitement des risques repose sur plusieurs approches complémentaires :

Réduction du risque

Mise en place de mesures de sécurité :

- MFA
- segmentation réseau
- supervision (SIEM)
- sauvegardes sécurisées

Évitement du risque

Modification des usages ou suppression de certaines pratiques à risque.

Transfert du risque

Externalisation ou assurance cyber.

Acceptation du risque

Dans le cas de risques faibles ou maîtrisés.

5.5.3. Priorisation des actions

Priorité 1 (immédiat)

- sécurisation des accès (MFA)
- protection Active Directory

- détection (SIEM / EDR)

Priorité 2 (court terme)

- classification des données
- mise en place PRA
- amélioration supervision

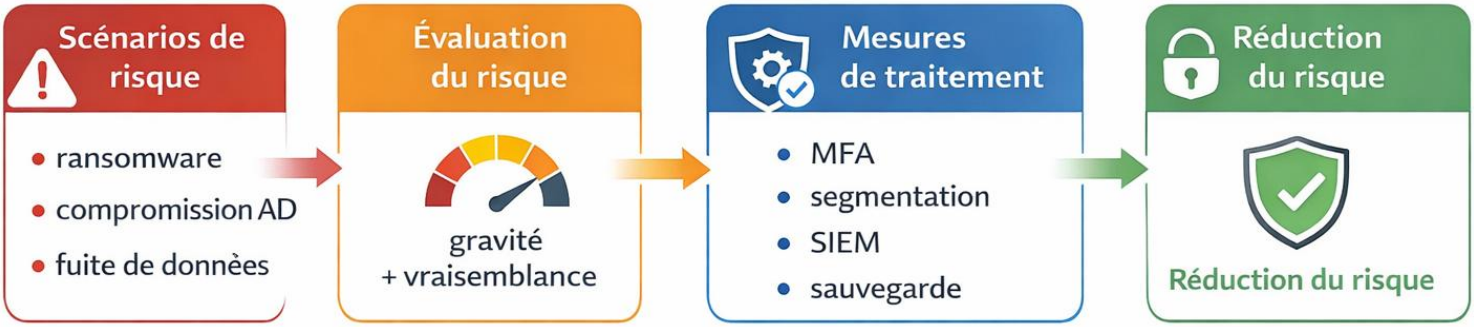
Priorité 3 (moyen terme)

- optimisation réseau
- gouvernance sécurité

Le schéma ci-dessous illustre le processus de traitement des risques, depuis l'identification des scénarios jusqu'à la mise en œuvre des mesures de sécurité.

Il met en évidence la logique d'amélioration continue, visant à réduire progressivement le niveau de risque du système d'information.

Cette étape permet de structurer l'analyse des menaces cyber, de proposer des mesures de sécurité cohérentes et de construire un plan de sécurisation ainsi qu'un plan de gestion de crise adaptés aux enjeux de l'organisation.



6. Comparatif des solutions du marché

6.1 Introduction

Il est nécessaire d'identifier et de comparer les solutions technologiques disponibles sur le marché.

L'objectif de cette analyse est de :

- sélectionner des solutions adaptées aux besoins de l'entreprise
- garantir un niveau de sécurité conforme aux référentiels (ISO 27001, ANSSI)
- assurer la cohérence globale de l'architecture cible

Cette étude porte à la fois sur :

- les solutions cloud
- les outils de sécurité
- les briques d'infrastructure critiques

6.2 Benchmark des solutions cloud

Méthodologie d'évaluation

Les solutions ont été comparées selon les critères suivants :

- Sécurité : conformité, IAM, outils natifs
- Intégration SI : compatibilité avec l'existant
- Fonctionnalités : richesse des services
- Disponibilité : SLA, redondance
- Coût : TCO, lisibilité
- Pertinence métier : adéquation avec SMARTFACTORY

Tableau comparatif cloud

Critère	***Microsoft Azure***	***AWS***	***Google Cloud***
Sécurité	5/5	5/5	4/5
IAM	5/5	5/5	4/5
Intégration	5/5	3/5	3/5
Complexité	Moyenne	Élevée	Moyenne
Disponibilité	5/5	5/5	5/5
Coût	Moyen	Variable	Compétitif
Pertinence SMARTFACTORY	5/5	4/5	3/5

Analyse

Les trois solutions offrent un haut niveau de sécurité et de disponibilité.

Cependant :

- AWS est très puissant mais complexe
- GCP est performant mais moins intégré
- Azure offre une cohérence forte avec les environnements d'entreprise

	Microsoft Azure	Azure	aws	Google Cloud
	Azure	AWS	GCP	GCP
Sécurité	Defender, Sentinel	• GuardDuty, CloudTrail	• Security Command Center	• Security Command Center
IAM	Azure Active Directory	• IAM, SSO AWS	• IAM, SSO AWS	• IAM, àccés Google
Intégration	Office 365, Hybride	• EC2, Lambda, Outposts	• EC2, Lambda, Outposts	• Workspace, Kubernetes
Coût	Flexibilité	• Paiement à l'usage	• 99,99 %	• Facturation à la seconde
Disponibilité	99,95 %	• 99,95 %	• 99,99 %	• 99,99 %

6.3 Choix de la solution cloud

Solution retenue : Microsoft Azure

Le choix de Microsoft Azure repose sur plusieurs éléments structurants.

Cohérence avec l'existant

- Active Directory
- environnement Microsoft

Sécurité intégrée

- Microsoft Defender (EDR)
- Microsoft Sentinel (SIEM)
- Entra ID

Simplification opérationnelle

- Centralisation
- réduction complexité

Conformité

- ISO 27001
- RGPD
- ANSSI

Microsoft Azure est retenu pour sa cohérence, sa sécurité intégrée et sa facilité d'intégration dans le système d'information existant.

Au regard de l'analyse comparative réalisée, la solution Microsoft Azure apparaît comme la plus adaptée au contexte de SMARTFACTORY.

Ce choix est repris dans la définition de l'architecture cible, où son intégration au reste des briques de sécurité est précisée.

6.4 Benchmark des briques de sécurité

La sécurisation du système d'information repose sur une approche multicouche, combinant plusieurs solutions complémentaires.

6.4.1 Gestion des accès (IAM / Bastion)

Solution	***Avantages***	***Limites***	***Coût***
Bastion (Wallix, CyberArk)	Contrôle total admin	Complexe	3/3
Entra ID / IAM	Centralisation	Dépend MS	2/3
MFA	Sécurité forte	UX	1/3

Analyse :

Le bastion est indispensable pour sécuriser les comptes à privilèges.

6.4.2 Sécurité réseau

Solution	***Avantages***	***Limites***	***Coût***
NGFW	Filtrage avancé	Coût	3/3
WAF	Protection web	Spécifique	2/3
IDS/IPS	Détection	Tuning	2/3

Analyse :

Une approche multicouche est nécessaire.

6.4.3 Protection postes et serveurs

Solution	***Avantages***	***Limites***	***Coût***
EDR	Détection avancée	Coût	2/3
Antivirus	Basique	Limité	1/3

Analyse :

L'EDR est indispensable face aux menaces modernes.

6.4.4 Supervision et détection

Solution	***Avantages***	***Limites***	***Coût***
SIEM	Corrélation	Coût	3/3
SOC	Supervision 24/7	Coûteux	3/3

Analyse :

La solution de supervision doit être évaluée selon sa capacité de collecte, de corrélation et d'intégration au reste de l'écosystème sécurité.

6.4.5 Sauvegarde

Solution	***Avantages***	***Limites***	***Coût***
Veeam	Fiable	Config	2/3
Backup cloud	Résilience	Dépend réseau	2/3

Analyse :

Les sauvegardes doivent être isolées.

6.4.6 ERP et applications critiques

Solution	***Avantages***	***Limites***	***Coût***
ERP (SAP, etc.)	Cœur métier	Critique	3/3
WAF	Protection	Spécifique	2/3

Analyse :

L'ERP doit être isolé et sécurisé.

6.5 Synthèse globale

L'analyse met en évidence que la sécurisation du système d'information repose sur une approche globale intégrant :

- une gestion des accès robuste
- une protection réseau multicouche
- une détection avancée
- une résilience forte

Aucune solution unique ne permet d'assurer la sécurité et c'est la combinaison cohérente des outils qui garantit un niveau de protection adapté.

7. Architecture cible sécurisée

7.1 Vision globale et choix des solutions

Pour donner suite à l'audit de l'existant et à l'analyse de risques menée avec la méthode EBIOS RM, l'architecture cible a été conçue afin de répondre aux failles identifiées, notamment en matière de gestion des accès, de segmentation réseau et de supervision.

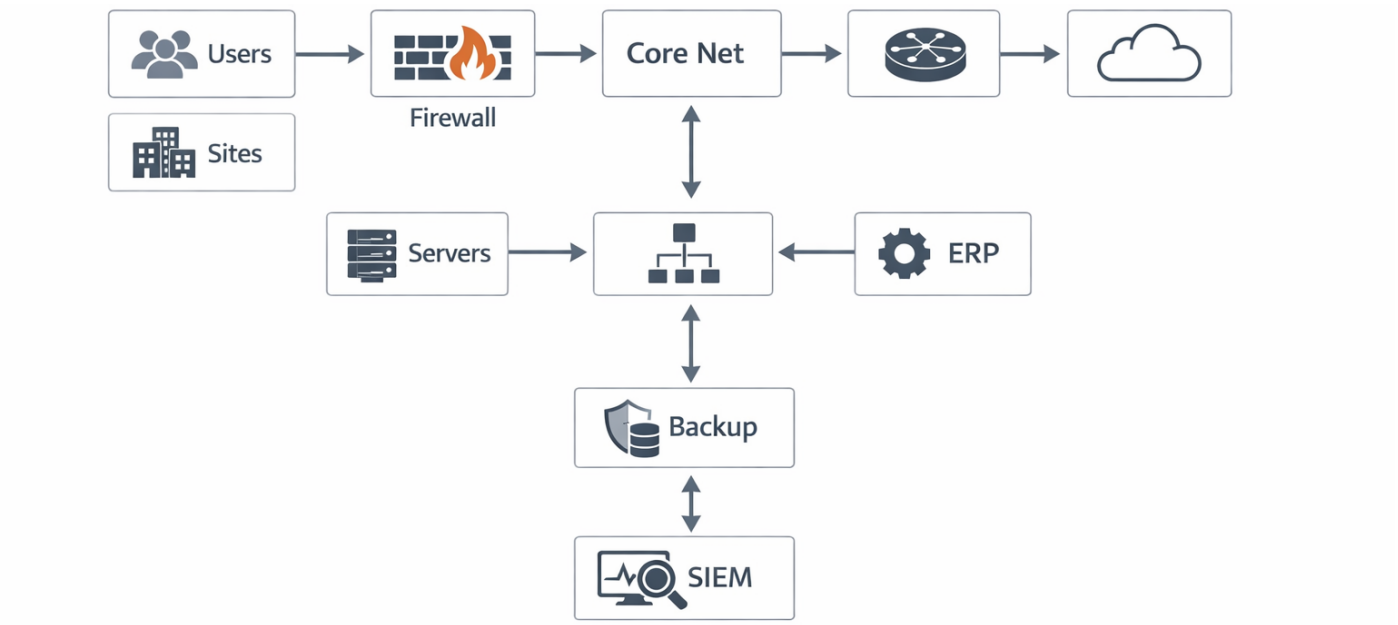
Le système d'information évolue vers une architecture sécurisée, structurée et supervisée, s'appuyant sur des solutions du marché sélectionnées lors du benchmark.

Le choix principal s'oriente vers un écosystème Microsoft, permettant de garantir une cohérence avec l'existant tout en facilitant la mise en œuvre des mesures de sécurité.

Les solutions retenues sont les suivantes :

- Gestion des identités : Microsoft Entra ID (IAM + MFA)
- Supervision : Microsoft Sentinel (SIEM)
- Protection des postes : Microsoft Defender for Endpoint (EDR)
- Pare-feu : NGFW (Fortinet / Palo Alto)
- Bastion : Wallix ou équivalent
- Sauvegarde : Veeam avec stockage isolé
- Protection web : WAF (Azure ou NGFW)

Cette sélection permet de centraliser la sécurité, de réduire la complexité et d'assurer une meilleure visibilité sur l'ensemble du système d'information.



7.2 Architecture système cible

L'architecture système repose sur une séparation claire des rôles des différents composants. Les serveurs sont organisés selon leur fonction afin de limiter les interactions et de réduire les surfaces d'attaque.

Les contrôleurs de domaine (Active Directory) sont isolés dans une zone sécurisée, accessible uniquement via des flux contrôlés. L'ERP, qui constitue un élément critique pour l'activité de l'entreprise, est également isolé afin de limiter les risques de compromission.

Les serveurs applicatifs et les bases de données sont séparés afin de renforcer la sécurité et de limiter les impacts en cas d'incident.

Les sauvegardes sont stockées dans un environnement dédié, isolé du reste du système d'information, afin de garantir leur disponibilité en cas d'attaque.

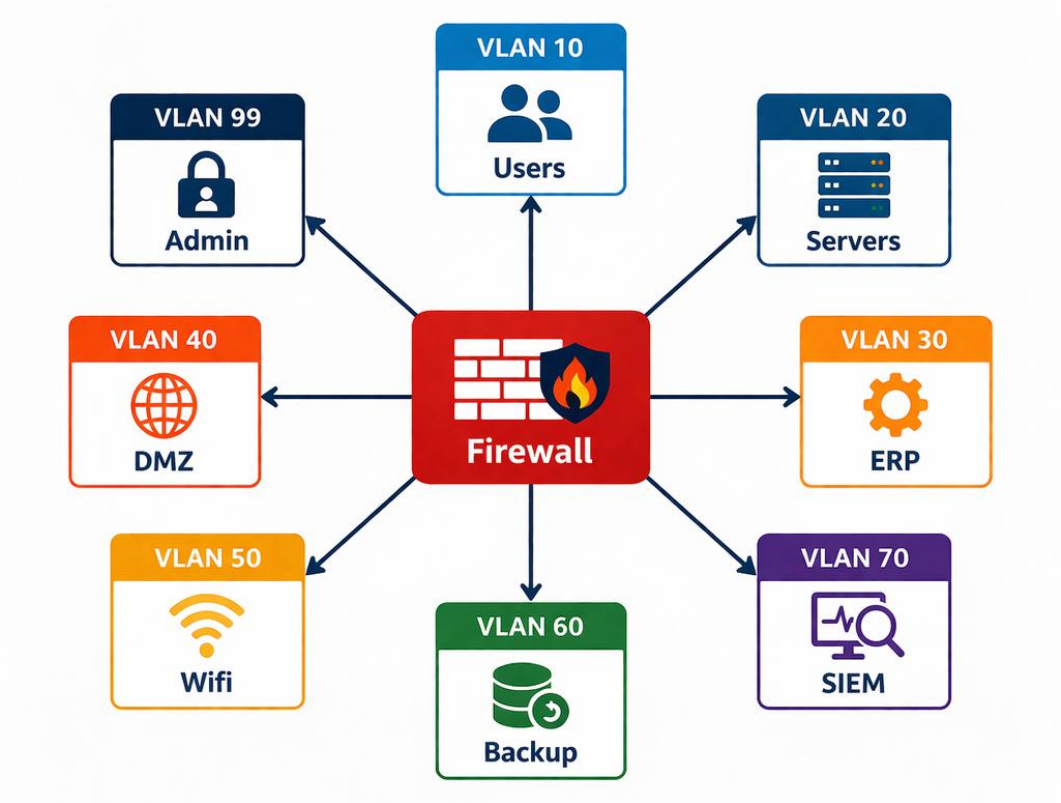
7.3 Architecture réseau et segmentation

Le réseau est segmenté en plusieurs VLAN afin de limiter les communications et de contrôler les flux.

Chaque type d'usage est isolé dans un segment dédié, ce qui permet de réduire considérablement les risques de propagation en cas d'attaque.

VLAN définis

VLAN	***Nom***	***Rôle***
10	USERS	Postes utilisateurs
20	SERVERS	Serveurs
30	ADMIN	Administration
40	ERP	Production
50	DMZ	Exposition
60	WIFI	Invités
70	BACKUP	Sauvegarde
80	SIEM	Supervision



Le firewall constitue le point central de contrôle des communications.

Chaque VLAN est isolé, et les flux entre les zones sont strictement contrôlés.

7.4 Gestion des flux et règles de filtrage

La gestion des flux repose sur une politique stricte basée sur le principe du “deny by default”. Seuls les flux nécessaires au fonctionnement du système sont autorisés.

Règles de filtrage

Source	***Destination***	***Ports / protocoles***	***Action***	***Justification***
USERS	AD / services d’authentification	53 DNS, 88 Kerberos, 123 NTP, 389/636 LDAP/LDAPS	ALLOW	Authentification et résolution de noms nécessaires au fonctionnement du domaine
USERS	ERP	443 HTTPS	ALLOW	Accès des utilisateurs à l’application métier
USERS	SERVERS fichiers / applicatifs autorisés	445 SMB, 443 HTTPS	ALLOW	Accès contrôlé aux ressources métiers nécessaires
USERS	Internet via proxy / filtrage web	80/443	ALLOW	Navigation contrôlée et filtrée
USERS	SERVERS non autorisés	ALL	DENY	Réduction de la surface d’attaque et limitation des déplacements latéraux
USERS	BACKUP	ALL	DENY	Interdiction d’accès direct aux environnements de sauvegarde
USERS	SIEM	ALL	DENY	Les utilisateurs n’ont pas à accéder à la plateforme de supervision
ADMIN via bastion	SERVERS	RDP 3389, SSH 22, WinRM 5985/5986	ALLOW	Administration sécurisée et tracée des serveurs
ADMIN via bastion	Équipements réseau / firewall	SSH 22, HTTPS 443	ALLOW	Administration des équipements d’infrastructure
ADMIN via bastion	AD / contrôleurs de domaine	RDP/SSH/LDAPs selon besoin	ALLOW	Administration restreinte des services d’identité
ADMIN hors bastion	SERVERS / AD / équipements réseau	ALL	DENY	Obligation de passer par le bastion pour toute administration
SERVERS	BACKUP	443 HTTPS, ports Veeam / dépôt autorisés	ALLOW	Exécution des sauvegardes et transferts vers le dépôt dédié
BACKUP	SERVERS	Flux de restauration autorisés uniquement pendant fenêtre contrôlée	ALLOW conditionnel	Restauration maîtrisée en cas d’incident ou de test
BACKUP	Internet	ALL	DENY	Réduction du risque d’exfiltration ou de compromission du dépôt
ERP	Base de données / serveurs applicatifs associés	Ports applicatifs / SQL strictement définis	ALLOW	Fonctionnement nominal de l’ERP
USERS	ERP base de données directe	ALL	DENY	Les utilisateurs ne doivent jamais accéder directement aux couches techniques

DMZ	SERVERS internes	Flux applicatifs strictement nécessaires uniquement	ALLOW limité	Cloisonnement des services exposés avec ouverture minimale
DMZ	AD / BACKUP / SIEM	ALL	DENY	Interdiction d'accès direct depuis la zone exposée vers les zones les plus sensibles
WIFI invités	Internet uniquement	80/443, DNS	ALLOW	Accès Internet isolé pour les visiteurs
WIFI invités	SI interne (USERS, SERVERS, ERP, ADMIN, BACKUP, SIEM)	ALL	DENY	Isolement complet du Wi-Fi invité
Équipements, serveurs, firewall, AD	SIEM	Syslog 514/6514, agents, logs Windows, API 443	ALLOW	Centralisation des journaux et supervision sécurité
SIEM	Sources supervisées	Requêtes d'administration / collecte strictement autorisées	ALLOW limité	Collecte, interrogation et enrichissement des événements
SIEM	Internet / Cloud sécurité	443 HTTPS	ALLOW	Envoi vers Sentinel / connecteurs cloud / CTI autorisée
Cloud M365 / Entra / Sentinel	SIEM / services internes exposés via connecteurs sécurisés	443 HTTPS	ALLOW	Centralisation des événements cloud et sécurité hybride
Tous VLAN internes	Internet sortant non justifié	ALL	DENY	Contrôle des flux sortants et réduction du risque d'exfiltration
Tous VLAN	Flux inter-VLAN non documentés	ALL	DENY	Application stricte du principe de moindre communication

Cette matrice illustre les principaux flux autorisés dans l'architecture cible, ainsi que les interdictions explicites destinées à protéger les zones les plus sensibles. Les ouvertures de flux doivent être validées, documentées et revues régulièrement. Les environnements d'administration, de sauvegarde, d'ERP, de supervision et de DMZ font l'objet d'un cloisonnement renforcé, conformément aux exigences de segmentation et de maîtrise des accès déjà identifiées dans l'audit et dans le plan de remédiation.

7.5 Sécurisation des accès et administration

L'architecture impose une séparation stricte entre comptes utilisateurs et comptes d'administration. Les accès à privilèges transitent exclusivement par un bastion et sont protégés par MFA. Cette organisation vise à réduire le risque de compromission des accès sensibles et à renforcer la traçabilité des actions d'administration.

7.6 Supervision et détection

L'architecture intègre une plateforme SIEM dédiée, positionnée dans la zone de supervision et alimentée par les principales sources du système d'information : Active Directory, équipements réseau, serveurs, services Microsoft 365 et solution EDR. Les flux de collecte sont strictement limités aux sources autorisées et sécurisés conformément à la matrice de flux. L'accès à la plateforme de supervision est restreint aux équipes habilitées. Dans cette architecture, le SIEM constitue un composant transverse de visibilité, de traçabilité et d'investigation, sans exposition directe aux utilisateurs.

7.7 Sauvegarde et résilience

La résilience de l'architecture repose sur des sauvegardes isolées, des tests réguliers de restauration et un cloisonnement des composants critiques. Cette logique vise à garantir la reprise des services essentiels en cas d'incident majeur.

8. Plan de remédiation et portefeuille projets

8.1 Approche méthodologique du plan de remédiation

Le plan de sécurisation proposé ne se limite pas à une simple liste d'actions techniques. Il s'inscrit dans une démarche structurée de gestion de projet, inspirée des bonnes pratiques du management de projet (type PMP), tout en restant adaptée au contexte de cybersécurité.

L'objectif est de garantir une mise en œuvre réaliste, pilotable et mesurable des actions de remédiation.

Ainsi, chaque projet de sécurisation est défini selon plusieurs dimensions :

- un objectif clair, lié à un risque identifié
- un périmètre maîtrisé
- des ressources associées
- un responsable désigné
- des indicateurs de suivi

Cette approche permet d'assurer une cohérence globale entre les différents chantiers, tout en facilitant leur pilotage.

Plutôt que de déployer les solutions de manière isolée, les actions sont organisées en un portefeuille de projets, permettant :

- de prioriser les efforts
- d'optimiser les ressources
- de gérer les dépendances
- de suivre l'avancement

Cette structuration facilite le suivi des actions, la gestion des dépendances et le pilotage du portefeuille projets.

8.2 Logique de priorisation

La priorisation des projets repose sur une analyse croisée des risques issus de la méthode EBIOS RM et des contraintes opérationnelles de l'entreprise.

Le premier facteur déterminant est la criticité du risque. Les scénarios pouvant impacter directement la production (ransomware, compromission AD) sont traités en priorité.

Le second facteur est la vraisemblance d'occurrence, permettant d'identifier les menaces les plus probables dans le contexte actuel.

Un troisième élément clé est la dépendance technique entre les projets. Par exemple, la mise en place du MFA est un prérequis pour sécuriser efficacement les accès cloud et les comptes administrateurs.

La priorisation prend également en compte le rapport effort / gain sécurité. Certaines mesures, peu coûteuses mais très efficaces (sensibilisation, MFA), sont déployées en priorité.

Enfin, les contraintes organisationnelles et budgétaires sont intégrées afin de garantir la faisabilité du plan.

Cette approche permet d'éviter une dispersion des efforts et d'assurer un déploiement progressif et cohérent des mesures de sécurité.

8.3 Plan de remédiation

Le plan de remédiation vise à traiter directement les écarts identifiés lors de l'audit et les risques issus de l'analyse EBIOS RM.

Chaque action est associée à un objectif précis, un risque traité et un résultat attendu.

Axe 1 : Sécurisation des accès (priorité critique)

La sécurisation des accès constitue le premier levier de réduction des risques.

Elle répond directement aux scénarios de compromission de comptes identifiés.

Les actions mises en œuvre incluent :

- déploiement du MFA sur l'ensemble des comptes
- mise en place d'une gestion centralisée des identités
- séparation des comptes utilisateurs et administrateurs
- revue régulière des habilitations

Résultat attendu :

Réduction drastique du risque de compromission du système d'information.

Axe 2 : Sécurisation du réseau et segmentation

L'absence de segmentation étant une vulnérabilité majeure, ce projet vise à restructurer le réseau.

Les actions incluent :

- mise en place des VLAN définis
- configuration des règles firewall
- isolation des environnements critiques

Résultat attendu :

Limitation de la propagation des attaques.

Axe 3 : Résilience et sauvegarde

Ce projet vise à garantir la continuité d'activité en cas d'incident.

Actions :

- mise en place de sauvegardes isolées

- application de la règle 3-2-1
- tests réguliers de restauration

Résultat attendu :

Capacité de reprise rapide après incident.

Axe 4 : Détection et supervision

La mise en place d'un SIEM permet d'améliorer la détection des incidents.

Actions :

- centralisation des logs
- mise en place de règles de détection
- supervision continue

Résultat attendu :

Réduction du temps de détection des incidents.

Axe 5 : Protection des postes et serveurs

Actions :

- déploiement EDR/XDR
- durcissement des systèmes
- gestion des correctifs

Résultat attendu :

Réduction des infections et compromissions.

Axe 6 : Sécurisation de l'administration

Actions :

- mise en place d'un bastion
- contrôle des accès admin
- traçabilité

Résultat attendu :

Maîtrise des accès à privilèges.

Axe 7 : Gouvernance et organisation

Actions :

- mise en place d'une démarche GRC

- suivi des risques
- tableaux de bord

Résultat attendu :

Pilotage structuré de la sécurité.

Axe 8 : Sensibilisation et procédures

Actions :

- formation utilisateurs
- procédures de sécurité
- gestion des incidents

Résultat attendu :

Réduction du facteur humain.

8.4 Tableau du portefeuille projets

Le tableau ci-dessous synthétise l'ensemble des projets de sécurisation, en mettant en évidence leur priorité, leur complexité et leur contribution à la réduction des risques.

Projet	***Objectif***	***Risque traité***	***Priorité***	***Complexité***	***Budget***	***Responsable***	***Échéance***	***Ressources clés***
MFA	Sécuriser les accès	Compromission de comptes	Critique	Faible	1/3	RSSI	Court terme	Admin M365, support, licences MFA, communication
Segmentation	Isoler les environnements réseau	Propagation latérale	Critique	Moyenne	2/3	IT	Court terme	Admin réseau, VLAN, règles firewall, cartographie flux
Backup	Renforcer la résilience	Ransomware	Critique	Moyenne	2/3	IT	Court terme	Admin systèmes, sauvegarde isolée, tests de restauration
SIEM	Améliorer la supervision	Détection tardive	Haute	Élevée	3/3	SecOps	Moyen terme	SecOps, logs, connecteurs, règles de détection
EDR	Protéger postes et serveurs	Malware / compromission endpoint	Haute	Moyenne	2/3	IT	Moyen terme	Admin postes, solution EDR, console, processus alertes
Bastion	Sécuriser l'administration	Compromission de comptes à privilèges	Critique	Moyenne	2/3	IT	Court terme	Admin infra, bastion, comptes séparés, procédure d'accès
M365	Sécuriser l'environnement cloud	Fuite de données / compromission cloud	Haute	Faible	1/3	IT	Court terme	Admin M365, MFA, accès conditionnel, revue des partages

PRA	Assurer la continuité d'activité	Interruption de service	Critique	Élevée	2/3	Direction	Moyen terme	DSI, métiers, sauvegardes fiables, environnement de test
GRC	Structurer le pilotage sécurité	Gouvernance insuffisante	Moyenne	Moyenne	1/3	RSSI	Long terme	RSSI, direction, outil GRC, suivi des actions
Sensibilisation	Réduire le risque humain	Phishing / erreurs utilisateurs	Haute	Faible	1/3	RH	Continu	RH, supports, campagnes, exercices phishing

8.5 Feuille de route

La feuille de route permet de planifier la mise en œuvre des projets dans le temps, en tenant compte des priorités et des dépendances.

Elle s'inscrit dans une logique progressive, visant à sécuriser rapidement les éléments critiques avant d'améliorer la maturité globale du système.

- **Court terme (0 à 6 mois)**

Cette phase vise à traiter les risques les plus critiques.

Actions principales :

- déploiement du MFA
- mise en place du bastion
- sécurisation des sauvegardes
- premières règles de segmentation réseau
- sécurisation M365

Objectif :

Réduction immédiate des risques majeurs (ransomware, compromission).

- **Moyen terme (6 à 18 mois)**

Cette phase vise à améliorer les capacités de détection et de réaction.

Actions :

- déploiement du SIEM
- mise en place de l'EDR
- formalisation du PRA
- amélioration de la supervision

Objectif :

Renforcer la résilience et la visibilité.

- **Long terme (18 mois et +)**

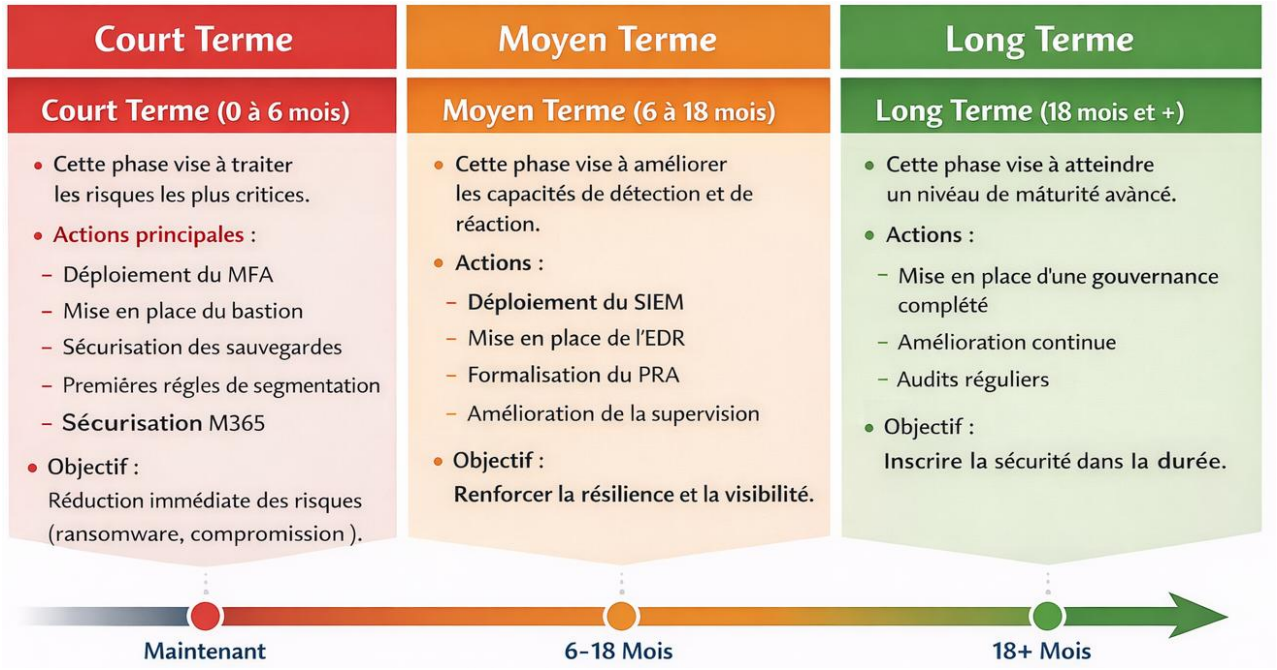
Cette phase vise à atteindre un niveau de maturité avancé.

Actions :

- mise en place d'une gouvernance complète
- amélioration continue
- audits réguliers

Objectif :

Inscrire la sécurité dans la durée.



9. Détection, supervision et surveillance des menaces

9.1 Besoin de surveillance du système d'information

La mise en place d'une architecture sécurisée ne suffit pas à garantir la protection du système d'information dans le temps. En effet, les menaces évoluent constamment et les attaques peuvent contourner certaines mesures de sécurité. Il est donc indispensable de mettre en place une capacité de surveillance continue afin de détecter les incidents le plus rapidement possible.

La surveillance répond à plusieurs objectifs fondamentaux.

Tout d'abord, elle permet d'assurer la disponibilité des services critiques, notamment les systèmes liés à la production industrielle. Une interruption non détectée peut avoir des conséquences directes sur l'activité de l'entreprise.

Elle vise également à détecter les compromissions du système, notamment suite à des attaques de type phishing ou exploitation de vulnérabilités. Dans ce contexte, la détection précoce est essentielle pour limiter l'impact.

La surveillance permet également d'identifier des mouvements suspects dans le réseau, tels que des tentatives de latéralisation ou des accès inhabituels entre les différents segments du système d'information.

Les échecs répétés d'authentification constituent également un indicateur important, pouvant révéler des tentatives de brute force ou d'usurpation d'identité.

Enfin, l'analyse des comportements anormaux (accès à des horaires inhabituels, volume de données anormal, actions inhabituelles) permet d'identifier des menaces plus avancées.

La surveillance continue permet surtout de réduire les délais de détection, de mieux qualifier les incidents et d'améliorer la capacité de réaction sur les périmètres critiques.

9.2 Outils de détection et de supervision retenus

Afin de répondre aux besoins identifiés, plusieurs outils complémentaires sont mis en œuvre, chacun couvrant un périmètre spécifique.

L'approche retenue repose sur une combinaison de solutions permettant d'assurer une visibilité globale du système d'information.

SIEM (Security Information and Event Management)

Le SIEM constitue le cœur du dispositif de supervision.

Dans l'architecture cible, il s'appuie sur Microsoft Sentinel, permettant de centraliser l'ensemble des journaux d'événements.

Il collecte les logs provenant :

- des firewalls
- des serveurs
- des postes utilisateurs
- des services cloud

Le SIEM permet de corréler ces événements afin d'identifier des scénarios d'attaque complexes. Il centralise les journaux utiles à l'analyse des événements de sécurité et permet la mise en place de règles de corrélation adaptées aux scénarios de risque retenus.

EDR (Endpoint Detection and Response)

L'EDR, déployé sur les postes et serveurs, permet de détecter les comportements suspects au niveau des terminaux.

Il est capable d'identifier :

- l'exécution de malware
- les comportements anormaux
- les tentatives d'escalade de privilèges

L'EDR complète ce dispositif en apportant une visibilité comportementale sur les postes et serveurs.

IDS / IPS (complément réseau)

Les mécanismes IDS/IPS permettent de surveiller le trafic réseau afin de détecter des signatures d'attaque ou des comportements suspects.

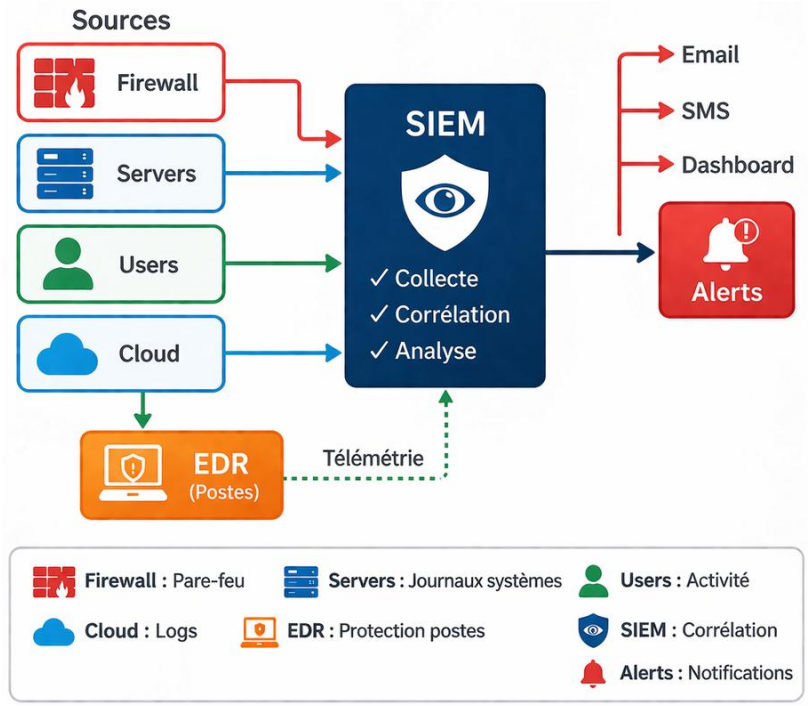
Ils complètent la vision apportée par le SIEM et l'EDR.

Supervision infrastructure

Des outils de supervision technique permettent de suivre :

- la disponibilité des serveurs
- les performances
- les services critiques

Cela permet de détecter rapidement une panne ou un incident.



9.3 Cas d'usage de détection

Afin de garantir l'efficacité du dispositif, des cas d'usage concrets de détection sont définis. Ils correspondent aux scénarios de risque identifiés précédemment.

Connexions anormales

Détection de connexions depuis :

- des localisations inhabituelles
- des horaires atypiques

Peut indiquer une compromission de compte.

Élévation de privilèges

Détection :

- ajout à un groupe administrateur
- modification de droits

Peut révéler une attaque sur l'Active Directory.

Chiffrement massif de fichiers

Détection :

- activité disque anormale
- modification massive de fichiers

Indicateur de ransomware.

Arrêt de services critiques

Détection :

- arrêt ERP
- arrêt AD

Impact direct sur la production.

Mouvements latéraux

Détection :

- connexions entre machines inhabituelles
- propagation réseau

Indicateur d'attaque avancée.

9.4 Processus de traitement des incidents

La détection d'un incident ne suffit pas : il est essentiel de définir un processus clair de gestion des incidents.

Ce processus s'inscrit dans une logique de réponse structurée, permettant de limiter les impacts.

Détection

L'incident est identifié via le SIEM ou l'EDR.

Qualification

Analyse de l'événement :

- vrai incident ou faux positif
- niveau de criticité

Escalade

Transmission à l'équipe compétente (IT / sécurité / direction).

Confinement

Actions immédiates :

- isolement machine
- blocage compte

- coupure réseau

Remédiation

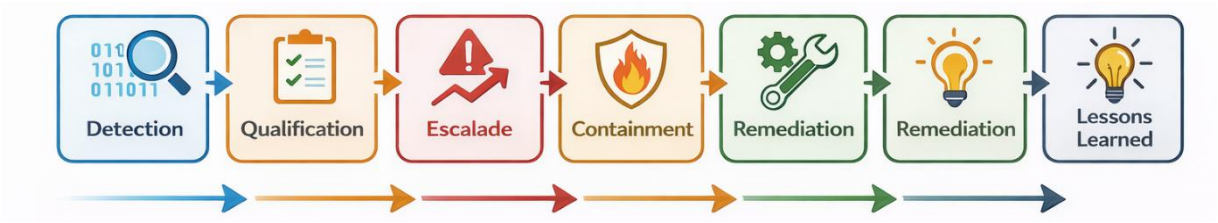
Correction :

- suppression malware
- restauration
- patch

Retour d'expérience

Analyse :

- cause racine
- amélioration



Ce schéma représente le cycle complet de gestion d'un incident de sécurité.

Il met en évidence l'importance d'une réaction rapide et structurée pour limiter les impacts.

9.5 Indicateurs de performance de la détection et de la réponse

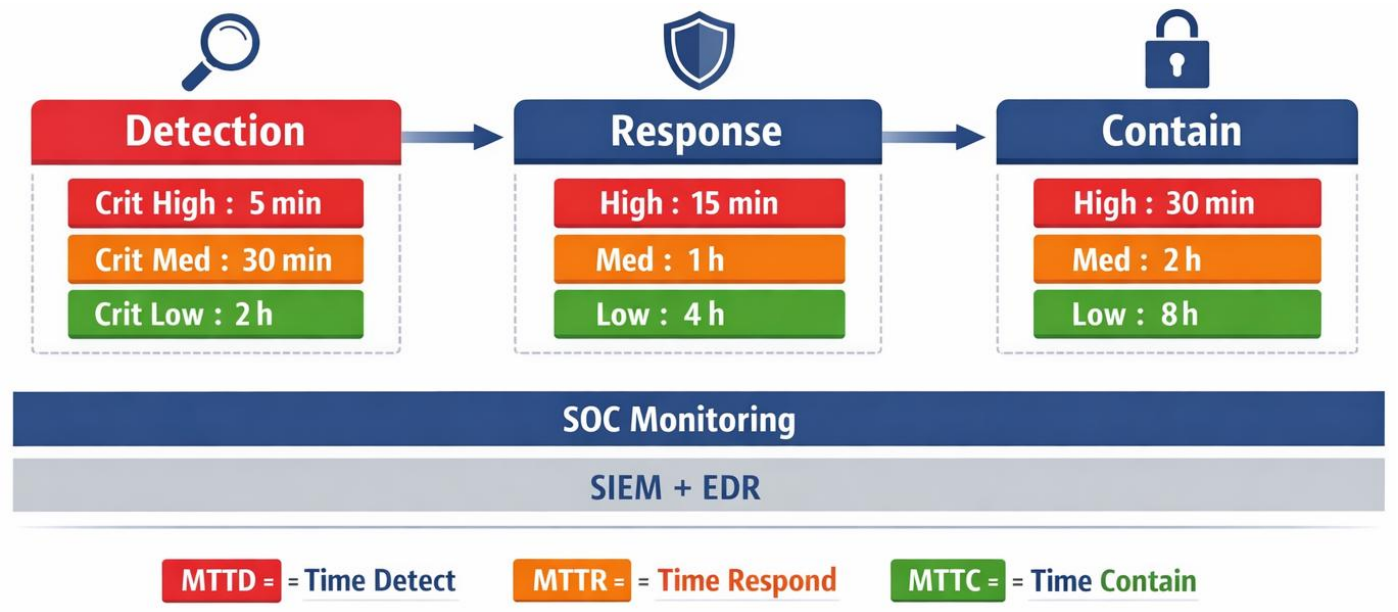
Afin d'évaluer l'efficacité du dispositif de supervision et de détection mis en place, plusieurs indicateurs de performance sont définis.

Le premier indicateur est le Mean Time To Detect (MTTD), qui mesure le temps moyen nécessaire pour identifier un incident de sécurité. Un MTTD faible permet de limiter l'impact des attaques en réduisant le délai de détection.

Le second indicateur est le Mean Time To Respond (MTTR), qui correspond au temps nécessaire pour réagir à un incident une fois celui-ci détecté. Cet indicateur reflète la capacité de l'organisation à mettre en œuvre des actions correctives rapidement.

Un troisième indicateur, le Mean Time To Contain (MTTC), peut également être utilisé afin de mesurer le temps nécessaire pour contenir une attaque et empêcher sa propagation.

Ces indicateurs permettent d'évaluer l'efficacité du dispositif de sécurité et d'identifier les axes d'amélioration. Ils s'inscrivent dans une logique d'amélioration continue et seront utilisés dans le cadre du pilotage global de la sécurité du système d'information.



10. Veille professionnelle et gouvernance de la sécurité

10.1 Organisation de la veille

La sécurisation du système d'information ne peut pas être considérée comme un état figé. Les menaces évoluent en permanence, tout comme les vulnérabilités, les techniques d'attaque et les obligations réglementaires. Dans ce contexte, la mise en place d'une veille professionnelle structurée constitue un élément essentiel pour maintenir un niveau de sécurité adapté aux enjeux de SMARTFACTORY.

L'objectif de cette veille est multiple. Elle permet tout d'abord d'identifier rapidement les vulnérabilités susceptibles d'impacter les systèmes utilisés par l'entreprise, notamment les environnements Microsoft, les équipements réseau et les solutions de sécurité. Elle permet également de suivre l'évolution des menaces, en particulier les campagnes de ransomware, les techniques de phishing ou les attaques ciblant les infrastructures industrielles.

Au-delà de l'aspect technique, la veille contribue également à la diffusion des bonnes pratiques et à l'amélioration continue des dispositifs de sécurité. Elle permet enfin d'alimenter la prise de décision, en fournissant des informations pertinentes à la direction et aux équipes techniques.

L'organisation de la veille repose sur une approche structurée. Une surveillance quotidienne est mise en place pour les alertes critiques, permettant une réaction rapide en cas de menace urgente. Une analyse hebdomadaire permet de consolider les informations pertinentes et d'évaluer leur impact sur le système d'information. Enfin, une revue mensuelle permet d'intégrer ces éléments dans une vision globale, en lien avec le pilotage de la sécurité.

Les parties prenantes de cette veille incluent le responsable sécurité, les équipes IT, les administrateurs systèmes et réseaux, ainsi que la direction pour les décisions stratégiques. Cette organisation garantit que la veille ne reste pas théorique, mais qu'elle est effectivement exploitée.

10.2 Sources de veille

La pertinence de la veille repose sur la qualité des sources utilisées. Dans le cadre de SMARTFACTORY, il est essentiel de s'appuyer sur des sources fiables, reconnues et alignées avec les standards internationaux.

Les sources institutionnelles constituent la base de la veille. L'ANSSI et le CERT-FR sont des références incontournables en France, fournissant des alertes, des recommandations et des guides adaptés au contexte national. Au niveau européen, ENISA permet de suivre les tendances globales des menaces et d'anticiper les évolutions du paysage cyber.

Du côté international, la CISA (États-Unis) publie des alertes critiques et maintient un catalogue des vulnérabilités activement exploitées. Le NIST, à travers la base NVD, permet de suivre les vulnérabilités de manière structurée.

Les éditeurs jouent également un rôle clé. Microsoft, Cisco, Fortinet ou encore Palo Alto publient régulièrement des bulletins de sécurité et des correctifs, essentiels pour maintenir les systèmes à jour.

Enfin, les sources internes, telles que les journaux SIEM, les alertes EDR et les retours d'incidents, permettent d'adapter la veille au contexte réel de l'entreprise.

Tableau des sources de veille

Source	***Type***	***Utilité***	***Fréquence***
ANSSI	Institution	Bonnes pratiques, guides	Hebdomadaire
CERT-FR	Institution	Alertes critiques	Quotidienne
ENISA	Européen	Tendances cyber	Mensuelle
CISA	US	Vulnérabilités actives	Quotidienne
NVD (NIST)	Base CVE	Vulnérabilités	Quotidienne
Microsoft	Éditeur	Patchs / M365	Quotidienne
Cisco / Fortinet	Éditeur	Réseau	Hebdomadaire
SIEM / EDR	Interne	Menaces réelles	Continue

10.3 Processus de veille et de diffusion

Pour être efficace, la veille doit suivre un processus structuré permettant de transformer l'information en action.

La première étape consiste à collecter les informations depuis les différentes sources. Ces données sont ensuite triées afin de ne conserver que les éléments pertinents pour le système d'information.

Une phase de qualification permet ensuite d'évaluer la criticité et l'impact potentiel de chaque information. Cette étape est essentielle pour prioriser les actions.

Les informations qualifiées sont ensuite diffusées aux parties prenantes concernées. Cette diffusion doit être adaptée au niveau de responsabilité, avec une approche plus technique pour les équipes IT et plus synthétique pour la direction.

Enfin, les informations issues de la veille doivent être traduites en décisions et en actions concrètes, telles que la mise à jour des systèmes, la modification des règles de sécurité ou l'évolution des priorités du plan de sécurisation.

Processus synthétique

Étape	***Objectif***
Collecte	Récupérer l'information
Tri	Filtrer
Qualification	Évaluer le risque
Diffusion	Informer
Décision	Arbitrer
Action	Corriger

10.4 Plan d'audit et lien avec la veille

Plan d'audit

La veille alimente directement le plan d'audit de sécurité. Elle permet d'adapter la fréquence, le périmètre et les priorités de contrôle en fonction des menaces identifiées, des vulnérabilités publiées, des incidents observés et des évolutions du système d'information.

Les audits sont organisés selon plusieurs niveaux. Des contrôles réguliers sont réalisés sur les accès, les sauvegardes, la supervision et le réseau. Des audits plus complets sont menés périodiquement afin d'évaluer le niveau global de sécurité. Enfin, des audits spécifiques peuvent être déclenchés à la suite d'une alerte critique, d'un incident de sécurité, d'une évolution technique majeure ou d'un changement réglementaire.

Audit	***Fréquence***	***Objectif***	***Parties prenantes***
Audit des accès	Trimestriel	Contrôler les habilitations, les comptes à privilèges et la conformité des droits d'accès	RSSI, DSI, administrateur Active Directory, RH, responsables métiers
Audit des sauvegardes	Semestriel	Vérifier l'exécution des sauvegardes, la capacité de restauration et la cohérence avec le PRA	DSI, administrateur systèmes, responsable PRA, RSSI
Audit du SIEM et de la supervision	Trimestriel	Évaluer la qualité de la collecte des logs, des règles de détection et du traitement des alertes	RSSI, SecOps, DSI, administrateur systèmes
Audit réseau et segmentation	Semestriel	Vérifier le cloisonnement des zones, les flux autorisés et la conformité des règles de filtrage	DSI, administrateur réseau, RSSI
Audit global de sécurité	Annuel	Obtenir une vision d'ensemble du niveau de sécurité, des écarts résiduels et des priorités de remédiation	Direction, RSSI, DSI, responsables métiers

La veille permet également d'ajuster ce plan d'audit dans le temps. Par exemple, la publication d'une vulnérabilité critique, la détection d'une campagne active par le CERT-FR ou une alerte issue du SIEM peut conduire à renforcer temporairement certains contrôles ou à déclencher un audit ciblé sur un périmètre particulier. Le plan d'audit reste ainsi dynamique et aligné sur le niveau de risque réel de l'organisation.

10.5 Gouvernance de la sécurité

La gouvernance de la sécurité a pour objectif d'organiser le pilotage des risques, des décisions et des actions de sécurisation dans la durée.

Elle repose sur une répartition claire des responsabilités entre direction, RSSI, DSI, équipes techniques et responsables métiers.

Elle doit permettre d'arbitrer les priorités, de suivre les écarts identifiés lors de l'audit, de valider les projets de remédiation et de mesurer l'évolution du niveau de sécurité.

Dans ce cadre, un pilotage régulier doit être assuré au travers de revues sécurité, de tableaux de bord et d'un suivi formalisé des plans d'action.

10.6 Pilotage via un outil GRC (CISO Assistant)

Afin de structurer durablement la gouvernance de la sécurité, SMARTFACTORY s'appuie sur un outil GRC tel que CISO Assistant. L'objectif n'est pas seulement de disposer d'un référentiel documentaire, mais de mettre en place un véritable outil de pilotage permettant de centraliser les risques, les écarts, les actions de remédiation, les indicateurs et les décisions de gouvernance.

Dans le contexte de SMARTFACTORY, CISO Assistant constitue le point de convergence entre plusieurs éléments déjà identifiés, les constats issus de l'audit, les exigences de conformité, les scénarios de risque EBIOS RM, le plan de remédiation, le portefeuille projets, les audits périodiques et les tableaux de bord de pilotage. L'outil permet ainsi de transformer une analyse ponctuelle en pilotage continu de la sécurité.

10.6.1 Rôle de CISO Assistant dans le dispositif de gouvernance

CISO Assistant est utilisé pour consolider dans un même espace de pilotage :

- les risques identifiés lors de l'analyse EBIOS RM
- les écarts de conformité relevés lors de l'audit
- les actions de remédiation décidées dans le plan de sécurisation
- les projets de transformation du portefeuille sécurité
- les indicateurs de suivi nécessaires au pilotage RSSI, DSI et direction
- les échéances de revue, d'audit et de contrôle

L'intérêt principal de l'outil est de relier chaque risque à des actions concrètes, à un responsable, à une échéance, à un statut d'avancement et à des éléments de preuve. Le pilotage ne repose donc plus sur une juxtaposition de documents, mais sur une vision consolidée et actualisable du niveau de sécurité.

10.6.2 Données pilotées dans l'outil

Domaine piloté	***Contenu suivi dans CISO Assistant***	***Exemple SMARTFACTORY***	***Finalité***
Registre des risques	Risque, gravité, vraisemblance, criticité, propriétaire, statut	Compromission de comptes à privilèges, propagation latérale, ransomware sur ERP, fuite de données sensibles	Prioriser les risques et suivre leur évolution
Écarts de conformité	Exigence, écart constaté, action attendue, preuve, échéance	Journalisation incomplète, MFA non généralisé, segmentation insuffisante, gouvernance peu formalisée	Suivre la mise en conformité
Plan d'actions	Action, responsable, priorité, date cible, statut, dépendances	Déployer le MFA, mettre en place le bastion, isoler les sauvegardes, activer le SIEM	Piloter la remédiation

Portefeuille projets	Projet, budget, complexité, sponsor, gains sécurité	Projet SIEM, EDR, PRA, segmentation, GRC	Arbitrer les priorités
Indicateurs	KPI, seuil, source, tendance, commentaire	Taux de patching, couverture EDR, sauvegardes OK, MTTD, MTTR, risque résiduel	Alimenter les tableaux de bord
Audits et revues	Type d'audit, fréquence, pilote, résultats, actions associées	Audit des accès, audit sauvegardes, audit SIEM, audit réseau	Assurer l'amélioration continue

10.6.3 Exemple de structuration du pilotage dans CISO Assistant

Référence	***Élément suivi***	***Action associée***	***Responsable***	***Échéance***	***Indicateur de suivi***
R-01	Compromission de comptes à privilèges	Déploiement du MFA, séparation des comptes, mise en place d'un bastion	RSSI / DSI	Court terme	% de comptes sensibles protégés par MFA
R-02	Propagation latérale sur le réseau	Segmentation VLAN, règles de filtrage inter-zones, durcissement des flux admin	DSI / Admin réseau	Court terme	% de flux documentés et validés
R-03	Ransomware affectant ERP et production	Sauvegardes isolées, tests de restauration, formalisation du PRA	DSI / Infra	Court terme à moyen terme	% de restaurations testées avec succès
R-04	Détection tardive d'un incident	Centralisation des logs, déploiement SIEM, cas d'usage de détection, EDR	RSSI / SecOps	Moyen terme	MTTD / MTTR
R-05	Traçabilité et conformité insuffisantes	Politique de journalisation, revues de droits, conservation des preuves	RSSI / DPO / DSI	Moyen terme	Taux de conformité des contrôles suivis

10.6.4 Workflow de pilotage

L'apport principal de CISO Assistant réside dans la mise en place d'un cycle de gouvernance continu. Pour SMARTFACTORY, ce cycle peut être décrit de la manière suivante :

- Identification : un risque, un écart de conformité, une vulnérabilité critique ou un incident est identifié à partir de l'audit, de la veille, du SIEM, d'un contrôle interne ou d'un exercice de crise
- Qualification : le RSSI qualifie l'élément, évalue sa criticité, rattache le risque à un actif ou à une valeur métier, puis propose une action de traitement
- Affectation : une action est créée dans CISO Assistant avec un responsable, une échéance, une priorité et, si besoin, un rattachement à un projet plus large
- Suivi : l'avancement est mis à jour régulièrement avec un statut, des commentaires, des preuves de réalisation et des éventuels points de blocage
- Revue : les éléments sont revus en comité sécurité ou en comité de pilotage afin d'arbitrer les priorités, de valider les reports et d'actualiser les décisions
- Mesure : les indicateurs consolidés permettent d'évaluer si le niveau de risque diminue réellement et si les actions produisent les effets attendus
- Réévaluation : les audits, incidents, résultats de tests PRA ou nouvelles menaces peuvent conduire à rouvrir un risque, ajuster une priorité ou lancer une nouvelle action

Cette logique permet d'apporter une traçabilité utile en cas d'audit, de revue de conformité ou de reporting à la direction.

10.6.5 Apport de l'outil à la décision

Pour le RSSI et la DSI, CISO Assistant sert à prioriser les actions, suivre les retards, arbitrer les dépendances entre projets et contrôler l'avancement réel des mesures de sécurité.

Pour la direction, il permet d'obtenir une vision synthétique du niveau d'exposition, des risques critiques ouverts, des chantiers en cours et des décisions à arbitrer.

Pour les équipes d'audit et de conformité, il constitue un support structuré pour démontrer la traçabilité des décisions, la mise en œuvre des actions et l'existence d'un cycle d'amélioration continue.

L'outil contribue donc à faire le lien entre sécurité opérationnelle, gouvernance, conformité et aide à la décision. Il renforce la crédibilité du pilotage en montrant que les constats issus de l'audit et de l'analyse de risques sont effectivement traduits en actions suivies dans le temps.

10.6.6 Limites et conditions de réussite

La mise en place d'un outil GRC ne produit de valeur que si son alimentation est régulière et si les responsabilités de mise à jour sont clairement définies. Pour SMARTFACTORY, cela suppose :

- une gouvernance claire entre direction, RSSI, DSI et métiers
- une mise à jour périodique des risques et des plans d'action
- une intégration des résultats issus de l'audit, de la veille, du SIEM et des revues de conformité
- une utilisation effective des tableaux de bord lors des revues de pilotage

Sans cette discipline, l'outil risquerait de devenir un simple référentiel documentaire. À l'inverse, bien exploité, CISO Assistant devient un levier structurant de pilotage et d'amélioration continue du niveau de sécurité.

11. Indicateurs, tableaux de bord et aide à la décision

11.1 Principes des indicateurs de sécurité

La mise en place d'un dispositif de sécurité efficace ne peut se limiter à l'implémentation de solutions techniques. Il est essentiel de disposer d'indicateurs permettant d'évaluer en continu le niveau de sécurité du système d'information, d'identifier les axes d'amélioration et d'aider à la prise de décision.

Les indicateurs retenus doivent permettre de suivre l'état réel de sécurité du SI, d'identifier rapidement les écarts et d'éclairer les décisions selon le niveau de responsabilité concerné. Les équipes techniques ont besoin d'indicateurs opérationnels orientés action, tandis que le pilotage RSSI/DSI et la direction attendent une vision plus synthétique, centrée sur les risques, l'avancement et l'impact métier.

11.2 Tableau de bord opérationnel

Le tableau de bord opérationnel est destiné aux équipes techniques. Il permet de suivre l'état de sécurité au quotidien et de réagir rapidement en cas de dérive.

Tableau opérationnel

Indicateur	***Objectif***	***Seuil cible***	***Source***	***Action associée***
Taux de patching	Corriger vulnérabilités	> 95%	Outils IT	Plan correctif
Couverture EDR	Protection postes	100%	EDR	Déploiement
Sauvegardes OK	Résilience	100%	Backup	Vérification
Incidents détectés	Surveillance	Suivi	SIEM	Analyse
MTTD	Détection rapide	< 30 min	SIEM	Ajuster règles
MTTR	Réaction rapide	< 1h	SOC	Améliorer process

Ce tableau permet aux équipes opérationnelles de suivre en temps réel l'état de sécurité. Il s'appuie sur les outils déployés (SIEM, EDR, sauvegarde) et permet d'identifier rapidement les écarts nécessitant une action.

11.3 Tableau de bord de pilotage (RSSI / IT)

Ce tableau de bord est destiné au pilotage global de la sécurité. Il permet de suivre l'avancement des projets et l'évolution du niveau de sécurité.

Tableau de pilotage

Indicateur	***Objectif***	***Source***	***Utilité***
Avancement projets	Suivi plan	GRC	Pilotage
Budget consommé	Suivi coûts	Finance	Arbitrage
Risques critiques ouverts	Réduction risques	GRC	Priorisation
Taux conformité	Respect normes	Audit	Suivi
Maturité sécurité	Évolution	GRC	Vision globale

Ce tableau permet de piloter la sécurité à un niveau stratégique. Il s'appuie fortement sur l'outil GRC (CISO Assistant), qui centralise les risques, les actions et les projets.

11.4 Tableau de bord direction (COMEX / Direction)

Ce tableau est destiné à la direction. Il doit être simple, synthétique et orienté métier.

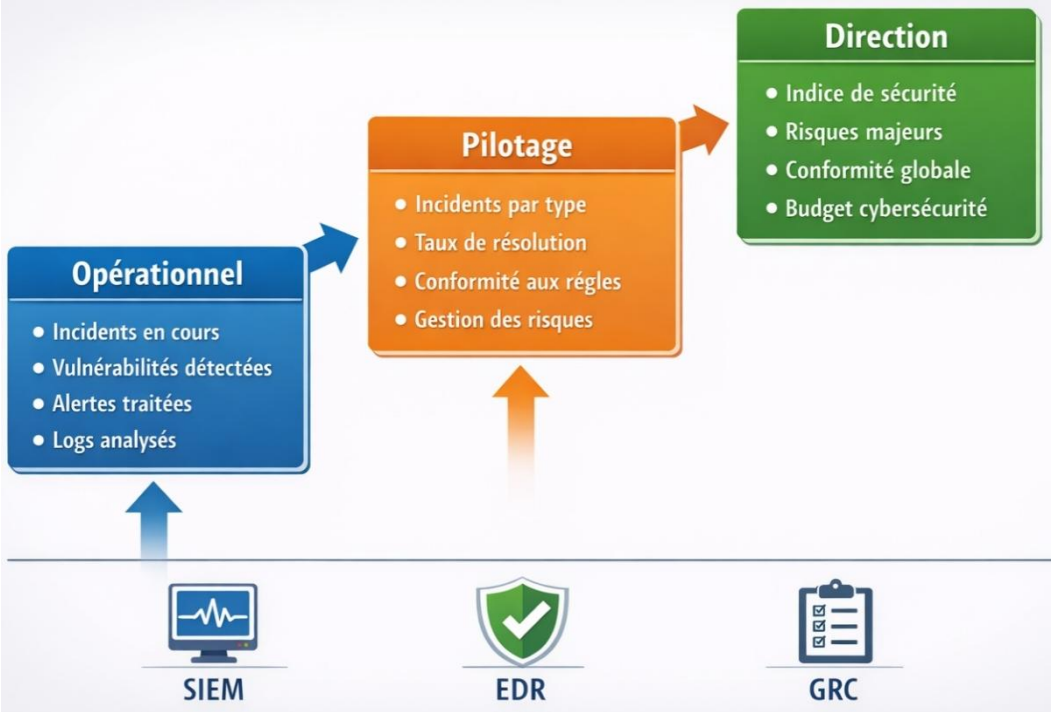
Tableau direction

Indicateur	***Objectif***	***Lecture***
Risque résiduel	Niveau global	Acceptable / critique
Disponibilité SI	Continuité	% uptime
Incidents majeurs	Impact	Nb / mois
Accès à privilèges conformes	Sécurité accès	% conformité
Avancement sécurité	Vision globale	%

Ce tableau permet à la direction de comprendre rapidement le niveau de sécurité et de prendre des décisions stratégiques, notamment en matière d'investissement ou de priorisation.

11.5 Lien avec les outils de supervision et GRC

Les tableaux de bord s'alimentent à partir des données issues du SIEM, de l'EDR, des outils d'administration et du dispositif de gouvernance. Leur consolidation permet de relier événements de sécurité, avancement des actions et niveau de risque résiduel. Ils constituent ainsi un support de pilotage opérationnel, tactique et directionnel.



12. PCA, PRA et plan de communication de crise

12.1 Principes de continuité et de reprise

Dans un contexte où le système d'information est fortement dépendant des activités métiers, la capacité à maintenir ou à restaurer les services en cas d'incident est un enjeu stratégique pour SMARTFACTORY.

Le Plan de Continuité d'Activité (PCA) vise à garantir le maintien des activités essentielles en cas de perturbation. Il s'agit de permettre à l'entreprise de continuer à fonctionner, même en mode dégradé, afin de limiter l'impact sur la production et les services.

Le Plan de Reprise d'Activité (PRA), quant à lui, intervient après un incident majeur. Son objectif est de restaurer le système d'information dans un état nominal, en s'appuyant notamment sur les sauvegardes et les procédures de restauration.

Ces deux dispositifs sont complémentaires. Le PCA permet de continuer à fonctionner pendant la crise, tandis que le PRA permet de revenir à la normale.

Dans le cadre de SMARTFACTORY, ces mécanismes sont essentiels compte tenu de la dépendance aux systèmes critiques tels que l'ERP, l'Active Directory et les services de communication.

12.2 Identification des services critiques

L'identification des services critiques permet de prioriser les actions en cas d'incident et de définir des objectifs de reprise adaptés.

Les principaux services critiques identifiés sont les suivants.

L'Active Directory constitue le cœur du système d'information. Il gère l'authentification et les accès. Sa compromission ou son indisponibilité a un impact global sur l'ensemble du SI.

L'ERP est un système central pour l'activité de production et de gestion. Son indisponibilité peut entraîner un arrêt de la production.

La messagerie et les outils collaboratifs sont essentiels pour la communication interne et externe.

Les interconnexions entre sites permettent la continuité des échanges et des opérations.

Les systèmes de sauvegarde sont indispensables pour assurer la reprise après incident.

Enfin, les services métiers spécifiques à l'activité industrielle doivent également être pris en compte.

12.3 Objectifs de reprise (RTO / RPO)

Afin de structurer la stratégie de reprise, des objectifs de reprise sont définis pour chaque service critique.

Le RTO (Recovery Time Objective) correspond au temps maximal acceptable pour restaurer un service.

Le RPO (Recovery Point Objective) correspond à la perte de données maximale acceptable.

Tableau RTO / RPO

Service	***Criticité***	***RTO***	***RPO***
Active Directory	Critique	2h	15 min
ERP	Critique	4h	30 min
Messagerie	Haute	6h	1h
Réseau inter-sites	Critique	2h	0
Sauvegarde	Critique	8h	1h
Services métiers	Haute	4h	30 min

Ces objectifs permettent de définir les priorités en cas de crise. Les systèmes critiques doivent être restaurés en priorité afin de limiter l'impact sur l'activité.

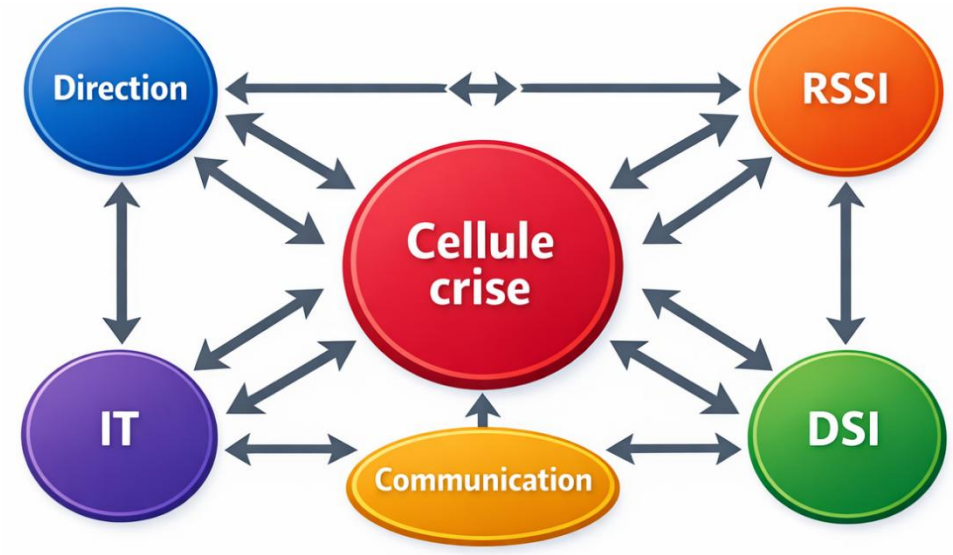
12.4 Organisation de la gestion de crise

Afin de rendre l'organisation de crise immédiatement exploitable, les rôles et responsabilités sont synthétisés dans le tableau ci-dessous. Cette présentation facilite l'activation de la cellule de crise, clarifie les circuits de décision et limite les ambiguïtés lors d'un incident majeur affectant les services critiques de SMARTFACTORY, notamment dans un scénario de ransomware avec compromission de l'Active Directory.

Acteur	***Rôle principal***	***Décide***	***Exécute***	***Informe***	***Remplace qui en cas d'absence***
Direction générale / COMEX	Valide les arbitrages majeurs, décide des priorités business, autorise les mesures exceptionnelles	Oui	Non	Oui	DSI
RSSI	Pilote la gestion de crise cyber, qualifie l'incident, coordonne les actions de sécurité et de confinement	Oui	Oui	Oui	DSI
DSI	Coordonne les opérations techniques, mobilise les équipes IT, supervise la reprise et le rétablissement	Oui	Oui	Oui	RSSI

Administrateurs systèmes et réseaux / équipe infrastructure	Met en œuvre les actions techniques : isolement, blocage, coupure de flux, restauration, contrôles techniques	Non	Oui	Oui, vers RSSI et DSI	Responsable infrastructure ou administrateur senior
Équipe sécurité / SecOps	Analyse les alertes, supervise le SIEM/EDR, collecte les indicateurs techniques, contribue à l'investigation	Non	Oui	Oui, vers RSSI	Administrateur sécurité désigné
Responsable communication	Prépare et diffuse les messages internes et externes validés, centralise la communication de crise	Non	Oui	Oui	Direction générale
Responsables métiers / sites	Remontent les impacts opérationnels, priorisent les besoins métier, valident le retour en service des activités	Non	Oui, sur le volet métier	Oui	Responsable de site ou adjoint métier
DPO / référent juridique si données concernées	Évalue les obligations réglementaires, notamment en cas de violation de données, et prépare les notifications nécessaires	Non	Oui	Oui	Direction générale ou conseil externe

Ce tableau permet de formaliser une organisation de crise simple, lisible et directement mobilisable. Il précise les responsabilités de décision, d'exécution et d'information pour éviter les doublons, les oublis ou les arbitrages tardifs. Il constitue ainsi un support opérationnel cohérent avec le PCA, le PRA et le scénario de crise étudié.



12.5 Plan de communication de crise

Afin de rendre le plan de communication de crise immédiatement exploitable, les principaux flux de communication sont synthétisés dans le tableau ci-dessous. Cette présentation permet d'identifier rapidement qui doit être informé, dans quel objectif, par quel canal, dans quels délais et sous quelle validation. Elle est particulièrement adaptée au scénario étudié, à savoir une attaque par ransomware avec compromission de l'Active Directory, pouvant affecter la production, l'ERP, les accès, la messagerie et les échanges inter-sites.

Public cible	Objectif	Message clé	Canal	Porte-parole	Délai	Validation préalable
Cellule de crise interne	Partager la situation initiale et déclencher la coordination	Incident majeur confirmé ou suspecté, activation de la cellule de crise, premières mesures engagées	Appel d'urgence, Teams, téléphone, messagerie de secours	RSSI / DSI	Immédiat	RSSI + DSI
Direction générale / COMEX	Permettre la prise de décision et l'arbitrage	Nature de l'incident, périmètre touché, impacts probables, décisions attendues	Brief oral, point de situation écrit synthétique	RSSI	Dans l'heure	RSSI
Équipes IT / sécurité / infrastructure	Donner les consignes d'action opérationnelle	Mesures de confinement, priorités techniques, systèmes à isoler, comptes à bloquer, points de contrôle	Téléphone, canal de crise, outil ITSM, messagerie de secours	DSI / RSSI	Immédiat	RSSI + DSI
Responsables métiers / responsables de site	Informer sur les impacts opérationnels et recueillir les besoins	Services affectés, consignes de continuité, procédures dégradées, estimation de reprise	Téléphone, mail de crise, point visio	Direction / DSI	Dans les 2 heures	Direction + RSSI
Ensemble des collaborateurs	Donner des consignes claires et éviter les erreurs	Incident en cours, comportements attendus, restrictions d'usage, consignes de signalement, interdiction d'initiatives non validées	Mail interne, intranet, SMS, affichage de consigne	Responsable communication	Dans les 2 heures	Direction + RSSI
Prestataires critiques / infogérance / partenaires techniques	Coordonner les actions de support ou de remédiation	Incident affectant certains services, niveau de mobilisation attendu, actions demandées, fenêtre d'intervention	Téléphone, mail, ticket prioritaire	DSI	Dans les 2 heures	DSI + RSSI
Clients / partenaires métier	Préserver la confiance et maîtriser l'image	Perturbation éventuelle de service, prise en charge en cours, continuité ou délais adaptés, point de contact unique	Mail, appel ciblé, message validé	Direction / Responsable communication	Selon impact confirmé	Direction générale
Autorités compétentes / CNIL si violation de données	Répondre aux obligations réglementaires	Nature de la violation, périmètre des données concernées, premiers constats, mesures engagées	Notification formelle, canal réglementaire	DPO / Direction	Selon obligation légale et qualification de l'incident	DPO + Direction + RSSI
Assureur cyber / assistance externe	Déclencher les dispositifs contractuels d'assistance	Date de détection, nature de l'incident, premiers impacts, demande d'accompagnement	Téléphone, portail assureur, mail	Direction / RSSI	Dès qualification initiale	Direction

Médias, si exposition publique	Contrôler la communication externe et éviter les messages contradictoires	Message factuel, limité, validé, sans détail technique non nécessaire	Communiqué ou réponse officielle unique	Direction / Responsable communication	Uniquement si nécessaire	Direction générale

Ce plan de communication permet de structurer les échanges pendant la crise et d'éviter les prises de parole non coordonnées. Il complète l'organisation de crise présentée en 12.4 et s'inscrit dans la logique du PCA, du PRA et du scénario de crise retenu. Il contribue également à la résilience globale du système d'information, en améliorant la coordination, la lisibilité des décisions et la maîtrise de l'impact réputationnel.

13. Gestion d'un scénario de crise cyber

13.1 Présentation du scénario retenu

Le scénario retenu pour cette étude correspond à une attaque par ransomware ayant pour origine une compromission initiale d'un poste utilisateur, suivie d'une propagation latérale dans le système d'information et d'une compromission de l'Active Directory. Ce scénario a été retenu car il représente l'un des risques les plus critiques pour SMARTFACTORY, à la fois par sa vraisemblance et par ses conséquences potentielles sur l'activité.

L'attaque débute par un courriel de phishing adressé à un collaborateur. L'utilisateur ouvre une pièce jointe ou clique sur un lien malveillant, ce qui permet l'exécution d'un code malveillant sur son poste. L'attaquant obtient ensuite un premier accès au système, puis cherche à élever ses privilèges, à découvrir l'environnement interne et à compromettre les comptes d'administration. Une fois l'Active Directory atteint, l'attaquant peut diffuser le ransomware à grande échelle, désactiver certains mécanismes de sécurité, altérer les accès et perturber fortement les opérations.

Dans un environnement tel que SMARTFACTORY, ce type d'attaque peut produire des effets immédiats sur les services critiques, notamment l'ERP, l'authentification, les fichiers partagés, les communications internes et les interconnexions entre sites. L'impact n'est donc pas uniquement informatique, il touche directement la continuité de production et la capacité de l'entreprise à fonctionner.

13.2 Détection de l'attaque

La première étape de la gestion de crise consiste à identifier les signaux annonciateurs de l'incident. Dans le cas d'un ransomware avec compromission AD, plusieurs indicateurs faibles peuvent apparaître avant la phase de chiffrement massif.

Du point de vue technique, le SIEM peut générer plusieurs alertes successives : augmentation anormale des échecs d'authentification, connexion depuis un poste utilisateur vers des ressources inhabituelles, création ou modification suspecte de comptes, élévation de privilèges, désactivation de journaux ou comportements anormaux sur les serveurs. L'EDR peut également remonter l'exécution d'un processus suspect, l'injection de code en mémoire, l'ouverture massive de fichiers ou encore l'apparition d'un outil connu pour le déplacement latéral.

Du point de vue métier, des symptômes peuvent être constatés très rapidement : lenteurs inhabituelles, accès refusés à certaines ressources, impossibilité d'ouvrir des documents, apparition de fichiers chiffrés, interruption de services critiques, messages d'erreur sur l'ERP ou impossibilité de se connecter au domaine.

La détection ne repose donc pas sur un seul événement, mais sur la corrélation de plusieurs signaux techniques et métiers. C'est précisément l'intérêt de la combinaison SIEM + EDR + supervision infrastructure. Le rôle de l'équipe sécurité consiste alors à ne pas traiter ces alertes comme des événements isolés, mais comme les éléments d'une séquence d'attaque cohérente.

13.3 Qualification de l'incident

Une fois les premiers signaux détectés, l'incident doit être qualifié rapidement afin de déterminer son niveau de gravité et les premières décisions à prendre.

La qualification porte en premier lieu sur la nature de l'attaque. Dans ce scénario, les éléments observés permettent d'identifier une attaque de type rançongiciel associée à une compromission d'identité, avec un fort soupçon d'atteinte à l'Active Directory. Cette combinaison augmente considérablement la gravité de l'incident, car elle laisse supposer une capacité de l'attaquant à se propager et à prendre le contrôle d'éléments critiques.

Elle porte ensuite sur le périmètre touché. Les premières vérifications doivent permettre de savoir si l'incident est limité à un poste, à un service, à une zone réseau, ou s'il concerne déjà plusieurs serveurs et comptes. Dans le cas étudié, le périmètre suspecté inclut un poste utilisateur compromis, plusieurs accès internes anormaux, au moins un compte à privilèges potentiellement compromis, et un risque de diffusion vers les environnements serveurs.

La qualification doit également évaluer la criticité. Ici, elle est immédiatement considérée comme élevée, voire critique, compte tenu du risque sur l'authentification centrale, sur l'ERP et sur la continuité d'activité. À ce stade, la cellule de crise doit être activée sans attendre une visibilité parfaite, car le temps joue en faveur de l'attaquant.

Enfin, il faut estimer les impacts probables à court terme. Ils peuvent inclure l'indisponibilité des comptes utilisateurs, le chiffrement de fichiers partagés, l'arrêt ou la dégradation de l'ERP, l'interruption partielle de l'activité, et la nécessité d'isoler rapidement certaines zones du système d'information.

13.4 Réponse immédiate et contre-mesures

La phase de réponse immédiate vise à ralentir l'attaque, à contenir sa propagation et à préserver la capacité de reprise. Elle doit être menée selon des procédures connues, avec des décisions rapides et coordonnées.

La première mesure consiste à isoler les équipements compromis. Le poste à l'origine des alertes doit être déconnecté du réseau, soit physiquement, soit par quarantaine via l'EDR si la solution le permet. Les serveurs ou segments suspects peuvent également être temporairement isolés selon le niveau de propagation observé.

La deuxième contre-mesure concerne les flux réseau. Des règles d'urgence peuvent être appliquées sur le firewall pour bloquer certains échanges entre VLAN, couper les communications suspectes, interrompre les flux vers l'extérieur ou restreindre temporairement les accès entre zones critiques. Cette mesure est particulièrement importante pour empêcher la latéralisation.

La troisième action vise à bloquer les comptes compromis ou suspects. Les comptes présentant des connexions anormales, des élévations de privilèges non justifiées ou des comportements incompatibles avec l'usage attendu doivent être désactivés ou forcés en réinitialisation. Si un compte d'administration est concerné, la réaction doit être immédiate.

La quatrième action est le gel des systèmes compromis, afin de préserver les preuves et d'éviter l'aggravation de la situation. Il ne s'agit pas seulement d'éteindre massivement les équipements, mais de choisir ce qui doit être stoppé, ce qui doit être isolé et ce qui doit être conservé pour l'analyse.

À ce stade, la cellule de crise doit également décider si le PRA doit être préparé, si certains services doivent être basculés en mode dégradé, et si une communication de crise doit être déclenchée.

Contre-mesures immédiates mises en œuvre dans le scénario

Mesure	***Objectif***	***Effet attendu***
Isolement du poste compromis	Stopper le point d'entrée	Limiter la propagation
Blocage des comptes suspects	Couper l'accès de l'attaquant	Empêcher l'escalade
Règles firewall d'urgence	Restreindre les flux latéraux	Contenir l'attaque
Quarantaine EDR	Neutraliser les terminaux touchés	Réduire le périmètre
Gel des systèmes compromis	Préserver preuves et état	Préparer l'analyse
Activation cellule de crise	Coordonner les décisions	Accélérer la réponse

13.5 Organisation opérationnelle de la crise

Dès que l'incident est qualifié comme critique, la cellule de crise cyber doit être activée. Le RSSI pilote la qualification de sécurité et la coordination des actions de confinement. La DSI coordonne les équipes techniques, les administrateurs systèmes et réseaux, et prépare les actions de reprise. La direction assure les arbitrages, notamment lorsque des décisions ont un impact fort sur l'activité. Le responsable communication encadre les messages internes et externes. Les équipes métiers concernées remontent les symptômes opérationnels et valident les priorités de reprise.

Cette organisation est essentielle pour éviter les réactions désordonnées. Sans cellule de crise, les décisions techniques risquent d'être prises sans vision métier, ou inversement. Dans un scénario de compromission AD, la coordination entre sécurité, exploitation et direction est particulièrement importante, car les mesures de confinement peuvent temporairement bloquer une partie du fonctionnement normal.

13.6 Restauration et rétablissement

Une fois la propagation contenue, l'objectif devient le rétablissement contrôlé du système d'information. Cette phase ne consiste pas à remettre en service le plus vite possible n'importe quel composant, mais à restaurer dans un ordre maîtrisé, avec vérification de l'intégrité.

La première priorité concerne les services structurants, en particulier l'Active Directory. Si sa compromission est confirmée, il ne faut pas simplement "redémarrer" les contrôleurs de domaine. Il faut vérifier la fiabilité des comptes, des objets, des groupes de sécurité et des mécanismes d'administration. Selon le niveau d'atteinte, une reconstruction partielle ou complète de certains composants AD peut être nécessaire.

La deuxième priorité porte sur les services métiers critiques, notamment l'ERP. Avant remise en production, il faut vérifier l'intégrité des bases de données, s'assurer que les comptes de service sont sains, et confirmer l'absence de mécanismes de persistance.

La troisième priorité concerne les fichiers partagés, la messagerie et les services périphériques. Leur rétablissement doit rester progressif afin d'éviter une rechute liée à un artefact malveillant encore présent.

La restauration s'appuie sur les sauvegardes, mais celles-ci doivent être vérifiées avant réintégration. Une sauvegarde disponible n'est utile que si elle est saine, cohérente et restaurable dans les délais attendus. C'est ici que les tests de restauration réalisés en amont prennent toute leur valeur.

La remise en production doit donc suivre un principe simple : restaurer, vérifier, réautoriser progressivement. Ce n'est qu'après ces contrôles que les utilisateurs peuvent retrouver un environnement nominal.

Ordre de rétablissement recommandé

Priorité	***Service***	***Action***
1	Active Directory	Restauration / contrôle intégrité
2	Services réseau essentiels	Rétablissement des échanges critiques
3	ERP et bases associées	Restauration contrôlée
4	Fichiers partagés	Réouverture progressive
5	Messagerie / collaboration	Reprise complémentaire
6	Services secondaires	Retour au nominal

13.7 Vérification d'intégrité avant remise en production

La phase de restauration doit être accompagnée d'une vérification méthodique. Il faut s'assurer que les systèmes restaurés ne réintroduisent ni ransomware, ni compte caché, ni tâche planifiée malveillante, ni modification non légitime de configuration.

Cette vérification s'appuie sur plusieurs éléments :

- analyse des journaux avant et après restauration
- contrôle des comptes et des groupes à privilèges
- vérification EDR sur les systèmes réintégrés
- contrôle des signatures, services démarrés et tâches planifiées
- validation fonctionnelle par les équipes métiers

Cette étape est essentielle. Une remise en production trop rapide sans contrôle d'intégrité peut conduire à une récidive immédiate de l'attaque.

13.8 Évaluation des dommages

Une fois la crise stabilisée, il est nécessaire d'évaluer les dommages subis. Cette évaluation ne se limite pas aux impacts techniques. Elle doit couvrir plusieurs dimensions.

Sur le plan opérationnel, il faut mesurer l'interruption ou la dégradation des services, le temps d'indisponibilité, le périmètre réellement touché et l'impact sur les processus métiers. Sur le plan technique, il faut identifier les actifs compromis, les comptes impactés, les données chiffrées ou détruites, et les composants qui ont dû être reconstruits.

Sur le plan organisationnel, il faut évaluer la mobilisation des équipes, les difficultés rencontrées, les points de blocage et les insuffisances des procédures. Sur le plan financier, il convient d'estimer le coût de l'arrêt, des actions de remédiation, des prestations externes éventuelles et du temps passé.

Enfin, si des données ont été exposées ou si des obligations réglementaires sont concernées, il faut apprécier les impacts juridiques et réputationnels.

13.9 Retour d'expérience et axes de renforcement

Le retour d'expérience est une étape indispensable. Une crise cyber bien gérée n'est pas seulement une crise terminée, c'est une crise qui améliore durablement le niveau de sécurité.

Dans le scénario étudié, plusieurs axes de renforcement peuvent être proposés.

Le premier axe consiste à renforcer encore la protection des identités, notamment par l'extension du MFA, le contrôle plus strict des privilèges, la revue des comptes de service et la surveillance renforcée des élévations de droits.

Le deuxième axe consiste à durcir la détection, en enrichissant les cas d'usage SIEM, en ajustant les règles de corrélation et en améliorant les mécanismes de quarantaine EDR.

Le troisième axe concerne la segmentation réseau et les règles de filtrage, afin de réduire davantage les capacités de déplacement latéral.

Le quatrième axe vise la maturité de reprise, en renforçant les tests de restauration, en validant les temps de reprise réels et en intégrant les enseignements de la crise dans le PRA.

Le cinquième axe concerne la préparation humaine, avec des exercices de crise, des formations et la mise à jour des consignes de communication.

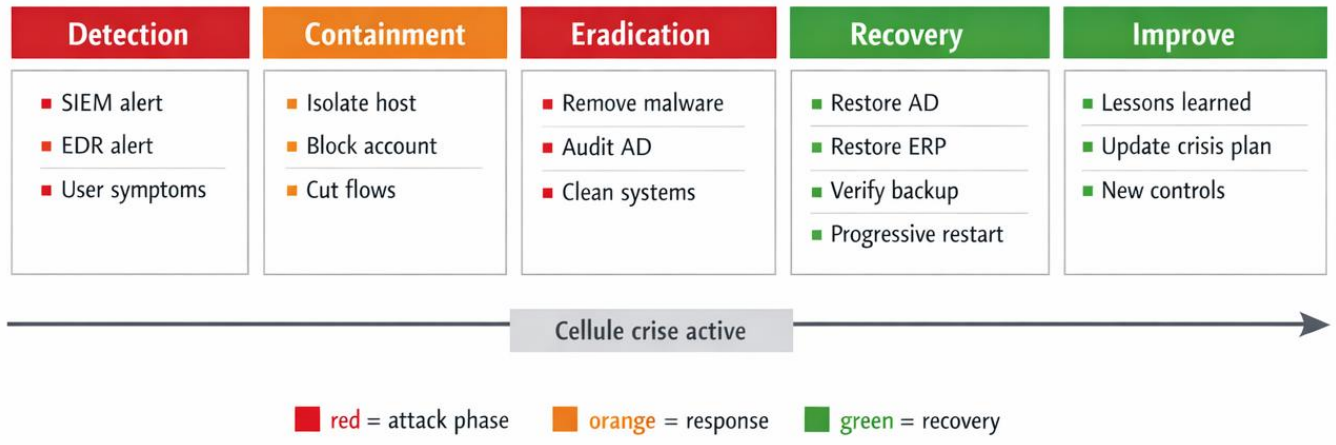
Axes de renforcement proposés

Axe	***Objectif***
Renforcement IAM / privilèges	Réduire le risque de compromission AD
Enrichissement SIEM / EDR	Améliorer la détection précoce
Segmentation complémentaire	Limiter la propagation
Tests PRA renforcés	Fiabiliser la reprise
Exercices de crise	Améliorer la coordination

13.10 Mise à jour du plan de crise

Le scénario de crise doit conduire à une révision du plan de crise cyber. Les procédures de qualification, de confinement, de restauration et de communication doivent être ajustées à partir des constats réalisés. Les rôles et responsabilités peuvent également être affinés, tout comme les critères de déclenchement de la cellule de crise.

Cette mise à jour permet d'éviter que l'organisation ne revive les mêmes difficultés lors d'un incident futur. Elle alimente également l'outil de gouvernance, qui peut enregistrer les écarts constatés, les actions d'amélioration et les échéances associées.



14. Synthèse managériale et recommandations finales

14.1 Résumé exécutif

Dans le cadre de cette mission, une analyse complète du système d'information de SMARTFACTORY a été réalisée, couvrant à la fois les aspects techniques, organisationnels et stratégiques de la cybersécurité.

L'audit de l'existant a mis en évidence plusieurs constats majeurs. Le système d'information, bien que fonctionnel et adapté aux besoins métiers, présente des faiblesses significatives en matière de sécurité. Ces faiblesses concernent notamment la gestion des accès, le cloisonnement réseau, la supervision, ainsi que la gouvernance globale de la sécurité. L'absence de certaines mesures essentielles, comme une authentification forte généralisée, une segmentation réseau avancée ou une supervision centralisée, expose l'entreprise à des risques importants.

L'analyse de risques, menée selon la méthode EBIOS RM, a permis d'identifier plusieurs scénarios critiques. Parmi eux, les attaques par ransomware, la compromission de l'Active Directory et les fuites de données apparaissent comme les menaces les plus structurantes. Ces risques sont d'autant plus critiques qu'ils peuvent impacter directement la continuité de production, la disponibilité des services et l'image de l'entreprise.

Face à ces constats, une trajectoire de sécurisation a été définie. Elle repose sur la mise en place d'une architecture cible sécurisée, intégrant des mécanismes de protection, de détection et de résilience. Cette trajectoire s'appuie également sur une approche structurée du pilotage de la sécurité, à travers la gouvernance, la supervision et la gestion des risques.

14.2 Priorités stratégiques de sécurisation

Afin de concentrer les efforts sur les leviers de réduction du risque les plus structurants, cinq priorités stratégiques sont retenues :

- généraliser la sécurisation des identités et des accès, avec MFA et contrôle renforcé des privilèges.
- mettre en place une segmentation réseau effective pour limiter les déplacements latéraux.
- déployer une supervision centralisée associant SIEM et EDR pour améliorer la détection.
- renforcer la stratégie de sauvegarde et de reprise afin de garantir la continuité d'activité.
- structurer le pilotage sécurité par une gouvernance formalisée et un suivi des risques dans la durée.

14.3 Bénéfices attendus

La mise en œuvre des recommandations proposées permettra à SMARTFACTORY d'améliorer significativement son niveau de sécurité et sa capacité à faire face aux menaces.

Le premier bénéfice est une réduction significative du niveau de risque. Les mesures mises en place permettent de limiter les probabilités de compromission et d'en réduire les impacts potentiels.

Le deuxième bénéfice concerne l'amélioration des capacités de détection. Grâce à la supervision centralisée et aux outils de sécurité, les incidents pourront être identifiés plus rapidement, réduisant ainsi leur impact.

Le troisième bénéfice est le renforcement de la résilience du système d'information. Les mécanismes de sauvegarde, de continuité et de reprise permettront à l'entreprise de maintenir son activité même en cas de crise majeure.

Le déploiement de ces mesures améliore également le pilotage de la sécurité, la capacité de suivi des actions et la démonstration de conformité vis-à-vis des exigences applicables.

Enfin, ces mesures contribuent à une meilleure conformité aux normes et aux bonnes pratiques, renforçant ainsi la confiance des partenaires, des clients et des parties prenantes.

Glossaire

Terme	***Définition***
AD	Active Directory, annuaire Microsoft utilisé pour gérer les comptes, groupes, postes et droits d'accès.
Altération	Modification non autorisée de données ou de configurations.
ANSSI	Agence nationale de la sécurité des systèmes d'information, autorité française de référence en cybersécurité.
Audit de sécurité	Évaluation structurée du niveau de sécurité d'un système d'information.
Bastion	Solution d'administration sécurisée servant de point d'entrée contrôlé pour les accès à privilèges.
Biens essentiels	Actifs directement liés aux valeurs métier et dont l'atteinte impacte fortement l'organisation.
Biens supports	Ressources techniques, humaines, physiques ou organisationnelles qui permettent aux biens essentiels de fonctionner.
Brute force	Tentative répétée de deviner un mot de passe ou un identifiant.
CERT-FR	Centre gouvernemental français de veille, d'alerte et de réponse aux attaques informatiques.
Chiffrement	Mécanisme transformant des données en contenu illisible sans clé.
CISA	Cybersecurity and Infrastructure Security Agency, agence américaine de cybersécurité.
CISO Assistant	Outil GRC utilisé pour centraliser risques, actions, conformité et indicateurs.
Cloud	Ressources informatiques hébergées à distance et accessibles via Internet.
COBIT	Référentiel de gouvernance et de pilotage des systèmes d'information.
COMEX	Comité exécutif, instance de direction stratégique.
Compromission	Perte de contrôle ou atteinte à la confidentialité, à l'intégrité ou à la disponibilité d'un système ou compte.
Compte à privilèges	Compte disposant de droits élevés sur le système d'information.
Confinement	Action consistant à contenir un incident pour éviter sa propagation.
Continuité d'activité	Capacité à maintenir les activités essentielles en cas d'incident.
Contrôle d'accès	Mécanisme déterminant qui peut accéder à quoi, quand et comment.
Corrélation des logs	Analyse croisée de plusieurs journaux pour détecter un comportement suspect.
Cube 1	Première phase du projet ayant défini ou modernisé l'architecture initiale du SI.
CVE	Identifiant standard d'une vulnérabilité connue.
DLP	Data Loss Prevention, mécanismes visant à prévenir la fuite de données.
DSI	Direction des systèmes d'information.
DMZ	Zone réseau intermédiaire exposée, isolée du réseau interne.
DNS	Service de résolution de noms en adresses IP.
Durcissement / Hardening	Renforcement de la sécurité d'un système par réduction de la surface d'attaque.
EBIOS RM	Méthode d'analyse de risques cyber portée par l'ANSSI.
EDR	Endpoint Detection and Response, solution de détection et de réponse sur postes et serveurs.
ENISA	Agence de l'Union européenne pour la cybersécurité.
Entra ID	Service Microsoft de gestion des identités et des accès.
ERP	Enterprise Resource Planning, progiciel central de gestion des processus métiers.

Escalade de privilèges	Obtention de droits plus élevés que ceux initialement accordés.
Exfiltration	Extraction non autorisée de données hors du système d'information.
Firewall / Pare-feu	Équipement ou logiciel qui filtre les flux réseau selon des règles définies.
Fuite de données	Divulgation non autorisée d'informations sensibles.
GRC	Gouvernance, Risques et Conformité.
IAM	Identity and Access Management, gestion des identités et des accès.
IDS	Intrusion Detection System, outil de détection d'intrusions réseau.
IPS	Intrusion Prevention System, outil de prévention d'intrusions réseau.
Indicateur de sécurité	Mesure permettant de piloter l'état de sécurité ou l'efficacité des actions engagées.
Intégrité	Garantie qu'une donnée n'a pas été modifiée de manière non autorisée.
ISO 27001	Norme de management de la sécurité de l'information.
ISO 27002	Norme de bonnes pratiques de sécurité de l'information.
Journalisation	Enregistrement des événements et actions dans des journaux.
KPI	Key Performance Indicator, indicateur clé de performance.
Latéralisation / Mouvement latéral	Déplacement d'un attaquant d'un système compromis vers d'autres systèmes du réseau.
Logs	Journaux techniques enregistrant les événements d'un système ou d'une application.
MFA	Multi-Factor Authentication, authentification multifacteur.
Microsoft Defender for Endpoint	Solution EDR de Microsoft.
Microsoft Sentinel	Solution SIEM de Microsoft.
MTTD	Mean Time To Detect, temps moyen de détection d'un incident.
MTTR	Mean Time To Respond, temps moyen de réponse à un incident.
MTTC	Mean Time To Contain, temps moyen de confinement d'un incident.
NIST	National Institute of Standards and Technology.
NVD	National Vulnerability Database, base de vulnérabilités associée au NIST.
NGFW	Next Generation Firewall, pare-feu avancé de nouvelle génération.
PCA	Plan de continuité d'activité.
Phishing	Technique d'hameçonnage visant à tromper un utilisateur pour voler des informations ou exécuter un code malveillant.
PRA	Plan de reprise d'activité.
Processus métier	Ensemble d'activités nécessaires au fonctionnement opérationnel de l'entreprise.
RACI	Matrice de répartition des rôles et responsabilités.
Rançongiciel / Ransomware	Logiciel malveillant qui chiffre les données et réclame une rançon.
RBAC	Role-Based Access Control, gestion des droits selon les rôles.
Référentiel	Ensemble structuré de bonnes pratiques, règles ou normes.
Résilience	Capacité à résister à un incident, à continuer à fonctionner et à se rétablir rapidement.
Rétablissement	Retour progressif à un fonctionnement normal après incident.
REX	Retour d'expérience après incident ou projet.
RGPD	Règlement général sur la protection des données.
Rôle	Ensemble de droits ou de responsabilités attribués à une fonction.
RPO	Recovery Point Objective, perte de données maximale acceptable.
RSSI	Responsable de la sécurité des systèmes d'information.

RTO	Recovery Time Objective, durée maximale acceptable d'indisponibilité d'un service.
Sauvegarde isolée	Copie de sécurité séparée logiquement ou physiquement du SI de production.
Scénario opérationnel	Description détaillée du mode opératoire d'une attaque.
Scénario stratégique	Scénario de risque reliant source de risque, vulnérabilité et impact métier.
SecOps	Équipe ou fonction en charge des opérations de sécurité.
Segmentation réseau	Découpage du réseau en zones distinctes pour limiter les communications et la propagation d'attaque.
SI	Système d'information.
SIEM	Security Information and Event Management, solution de collecte, corrélation et analyse des journaux.
SLA	Service Level Agreement, engagement de niveau de service.
SMSI	Système de management de la sécurité de l'information.
SOC	Security Operations Center, centre opérationnel de supervision sécurité.
Source de risque	Acteur ou cause susceptible d'atteindre les biens essentiels.
Supervision	Surveillance continue de l'état des systèmes et des événements.
Surface d'attaque	Ensemble des points exploitables par un attaquant.
TCO	Total Cost of Ownership, coût total de possession.
Traçabilité	Capacité à reconstituer les actions et événements passés.
VLAN	Réseau local virtuel permettant de segmenter logiquement un réseau.
VPN	Virtual Private Network, tunnel de communication sécurisé.
Vraisemblance	Probabilité d'occurrence d'un scénario de risque.
WAF	Web Application Firewall, pare-feu applicatif web.
Wi-Fi invité	Réseau sans fil isolé destiné aux visiteurs.
XDR	Extended Detection and Response, détection et réponse étendue à plusieurs couches du SI.